[Company Name]

This is a SAMPLE report and does not include all therequirements of evidence to fulfill SACS-002 Audit /Assessment, additional evidence, artificats might berequired to confirm the control statement - TPC

Disclaimer: The contents of this report should be treated as Confidential and is intended solely for the use of the individual or entity to which it is addressed. This report may contain legally privileged information and may not be disclosed or forwarded to anyone else without authorization from the Supply Chain and Third Party Compliance Group. This assessment is current "system state" dependent, meaning any modifications other than those recommended in the report after the date of the assessment renders this assessment invalid. The assessment was based on sampling and therefore non-implementation items may exist.

1. Document Control 3
2. Third Party Information 4
3. Audit Firm Information 5
3.1 Report Control 5
3.2 Assessors 5
3.3 Approved by 5
4. Guidelines 6
5. Executive Summary 7
6. Assessment Controls 8
6.1 General Requirments 8
7. Report Summary 55
Appendix A- Third Party Classification 55

Saudi Aramco: Confidential

1. Document Control

Version	Date
1.0	MM/DD/YY

Saudi Aramco: Confidential

2. Third Party Information

Company Name	**Click here to enter text.**	
Vendor ID	Click here to enter text.	
Business Address	**Country**	Click here to enter text.
	City	Click here to enter text.
	Address	Click here to enter text.
Third Party Classification	*Note: The third Party must be classified according to the Third Party Classification described in Appendix A. ✓ General Requirements (Applicable on all third parties) ☐ Outsourced Infrastructure ☐ Customized Software ☐ Network Connectivity ☐ Critical Data Processor	
Contact Person	**Name**	Click here to enter text.
	Position	Click here to enter text.
	Email	Click here to enter text.
	Phone	Click here to enter text.
	Mobile Number	Click here to enter text.

Saudi Aramco: Confidential

3. Audit Firm Information

*This section to be filled by the Audit Firm

3.1 Report Control

Version	Date	Author	Comment
0.1	MM/DD/YYYY	Assessor	Initial Draft
1.0	MM/DD/YYYY	Reviewer	Final

3.2 Assessors

Name	Date
Click here to enter text.	MM/DD/YYYY
Click here to enter text.	MM/DD/YYYY

3.3 Approved by

Entity	Signature	Date
Name, Administrator		MM/DD/YYYY
Name, Administrator		MM/DD/YYYY

Saudi Aramco: Confidential

4. Guidelines

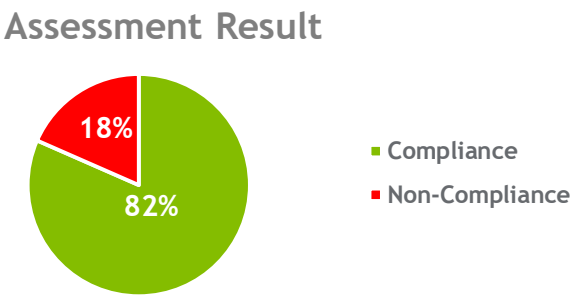
1. Third Party must fill all of the fields.
2. Third party must ensure the answers are comprehensive, clearly described, and attach supporting documents.
3. Kindly make sure to follow the below:
   3.1. Evidences must be clear and readable and must be time stamped.
   3.2. Evidences must show a proof that it is related to the Third Party.
   3.3. Clearly point out/highlight the evidences in the screenshots.
4. Third Party must provide valid justification for Not Applicable controls and these questions must be added to the Inapplicability form and signed by the Third Party.
5. All cybersecurity controls specified in the SACS-002 Third Party Cybersecurity Standard must be implemented on:
   5.1. All Third Party information systems and/or Assets used to connect to Saudi Aramco's network.
   5.2. All Third Party's Assets hosting, receiving, storing, processing or transmitting Saudi Aramco data. These Assets must be secured and stored in keeping with this Standard and must be made available to authorized users on a need-to-know basis.
6. At a minimum, all Third Parties must comply with all cybersecurity controls specified as General Requirements in the SACS-002 Third Party Cybersecurity Standard.
7. The signed/stamped compliance assessment report to be communicated by the audit firm to the third party. As a result, the third party should upload the signed/stamped report through Saudi Aramco e-marketplace (SAP Ariba).
8. **Kindly filter the controls in the Specific Requirements section according to Third Party classification (a Third Party may fall under more than one class).**

Saudi Aramco: Confidential

5. Executive Summary

The purpose of this cybersecurity assessment is to confirm that [Third Party] has implemented the general requirement information security controls defined in the Third Party Cybersecurity Standard (SACS-002) in addition to the relevant controls as per the Third Party classification. This assessment capture and document a point-in-time implementation status of the existence of the applicable controls as per the Third Party Cybersecurity Standard (SACS-002).

The Cybersecurity Assessment Report identifies and highlights the areas of concern which must be addressed by the third party to acquire the third party cybersecurity compliance certificate that requires full compliance with the Third Party Cybersecurity Standard (SACS-002). The Information Security controls implementation status in [Third Party] is illustrated in the below chart.



This assessment has been conducted based on the information provided by the third party that indicates their cybersecurity posture at the time of the assessment. Audit firm has not evaluated the adequacy or appropriateness of the Standard compiled by Saud Aramco. Audit Firm evaluation was limited to assessment against Saudi Aramco Third Party Cybersecurity Standard (SACS-002) and should not be relied upon as an assurance beyond the areas covered by this Standard. This assessment does not guarantee protection against cyber threats, loss of critical data or network intrusion.

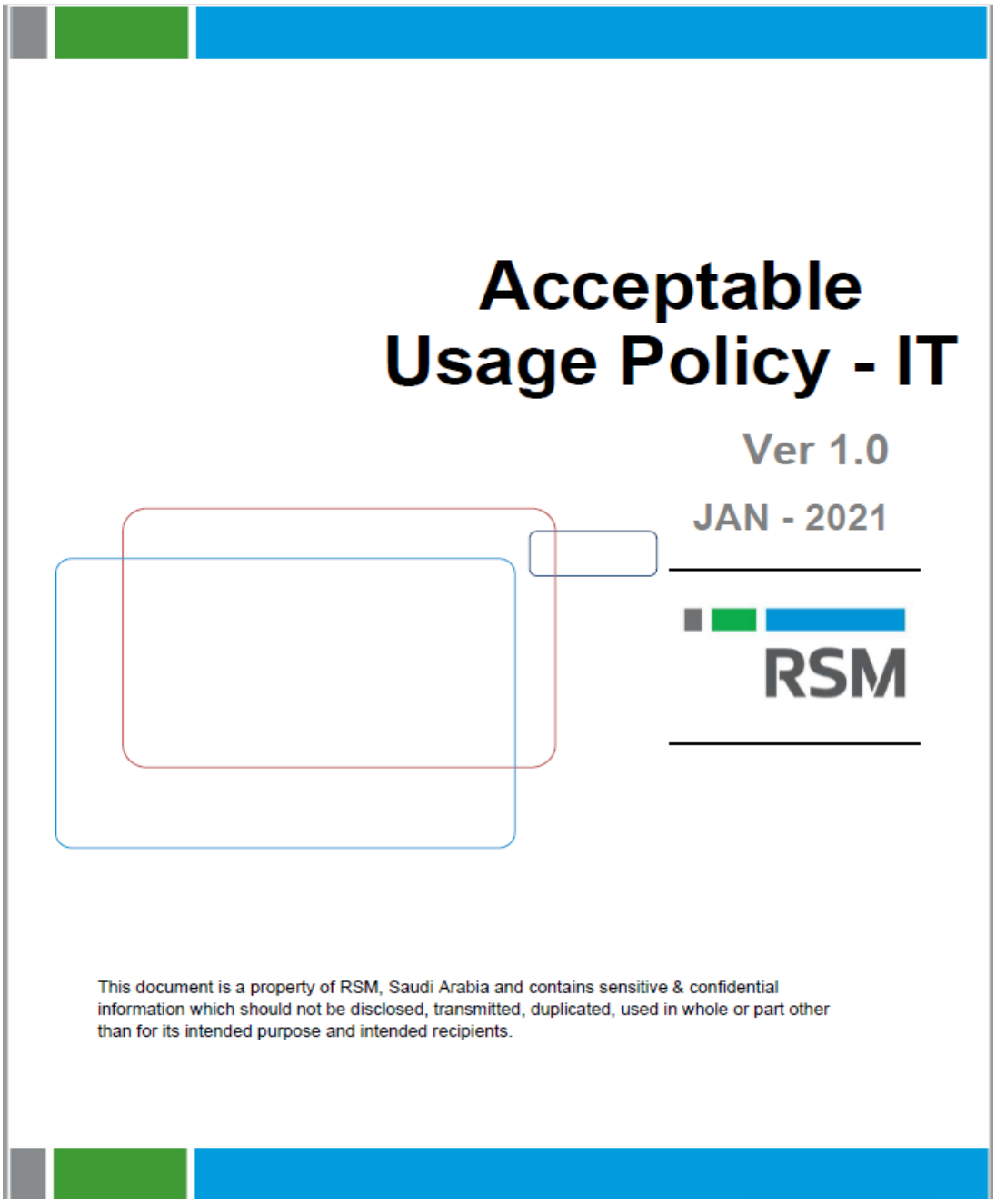
Saudi Aramco: Confidential

6. Assessment Controls

6.1 General Requirments

Control #	1	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-1	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must establish, maintain and communicate a Cybersecurity Acceptable Use Policy (AUP) governing the use of Third Party Technology Assets.		
Supporting Evidence			

#SS1.1



Saudi Aramco: Confidential

Control #	1	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-1	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must establish, maintain and communicate a Cybersecurity Acceptable Use Policy (AUP) governing the use of Third Party Technology Assets.		

#SS1.2

Document Version Control					
Version No.	Date	Author	Reviewer	Approver	Change Description
1.0	08th July, 2020	Em	Em	A..	Initial Version

Table of Contents

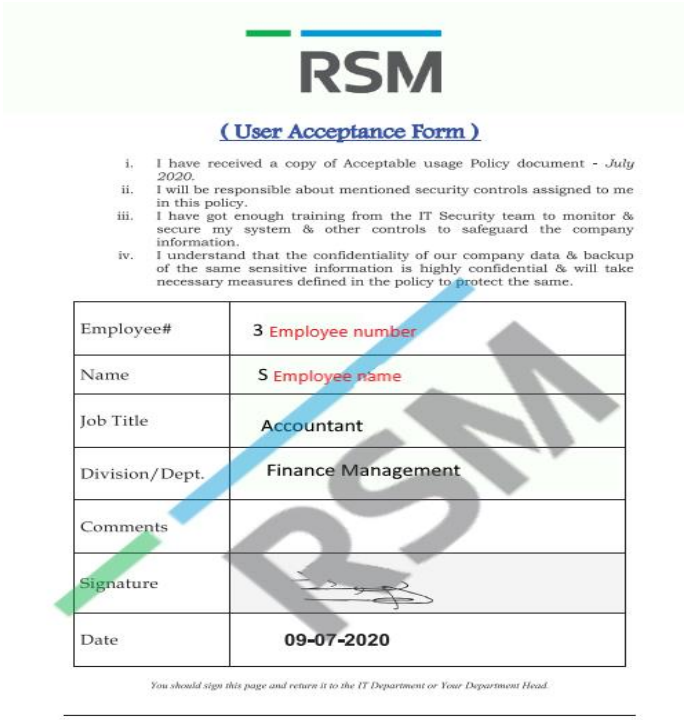
A. BACKGROUND 3
B. OBJECTIVE 3
C. SCOPE 3
D. POLICY STATEMENTS 4
1) GENERAL USE AND OWNERSHIP POLICY 4
2) END-USER SYSTEM USAGE POLICY (DESKTOPS AND LAPTOPS) 5
3) NETWORK AND FILE SERVICES USAGE POLICY 7
4) E-MAIL SERVICES USAGE POLICY 8
5) SECURE INTERNET USAGE POLICY 11
6) SOCIAL MEDIA SECURITY POLICY 12
7) MOBILE PHONE USAGE POLICY 14
8) CLEAR DESK POLICY 16
E. DISCIPLINARY ACTION 20
F. EXCEPTION 20
G. OWNERSHIP 20
H. REVIEW 20

RSM

Saudi Aramco: Confidential

Control #	1	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-1	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must establish, maintain and communicate a Cybersecurity Acceptable Use Policy (AUP) governing the use of Third Party Technology Assets.		

#SS1.3



RSM

(User Acceptance Form)

i. I have received a copy of Acceptable usage Policy document - *July 2020.*
ii. I will be responsible about mentioned security controls assigned to me in this policy.
iii. I have got enough training from the IT Security team to monitor & secure my system & other controls to safeguard the company information.
iv. I understand that the confidentiality of our company data & backup of the same sensitive information is highly confidential & will take necessary measures defined in the policy to protect the same.

Employee#	3 Employee number
Name	S Employee name
Job Title	Accountant
Division/Dept.	Finance Management
Comments	
Signature	
Date	09-07-2020

You should sign this page and return it to the IT Department or Your Department Head.

#SS1.4



RSM

(User Acceptance Form)

i. I have received a copy of Acceptable usage Policy document - *July 2020.*
ii. I will be responsible about mentioned security controls assigned to me in this policy.
iii. I have got enough training from the IT Security team to monitor & secure my system & other controls to safeguard the company information.
iv. I understand that the confidentiality of our company data & backup of the same sensitive information is highly confidential & will take necessary measures defined in the policy to protect the same.

Employee#	3 Employee number
Name	M Employee name
Job Title	Business Analyst
Division/Dept.	Transaction Advisory
Comments	
Signature	
Date	09-07-2020

You should sign this page and return it to the IT Department or Your Department Head.

Saudi Aramco: Confidential

Control #	1	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-1	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must establish, maintain and communicate a Cybersecurity Acceptable Use Policy (AUP) governing the use of Third Party Technology Assets.		

#SS1.5

RSM

(User Acceptance Form)

i. I have received a copy of Acceptable usage Policy document - *July 2020.*
ii. I will be responsible about mentioned security controls assigned to me in this policy.
iii. I have got enough training from the IT Security team to monitor & secure my system & other controls to safeguard the company information.
iv. I understand that the confidentiality of our company data & backup of the same sensitive information is highly confidential & will take necessary measures defined in the policy to protect the same.

Employee#	4Employee number
Name	H-Employee name
Job Title	**Reception Manager**
Division/Dept.	**Reception**
Comments	
Signature	
Date	**09-07-2020**

You should sign this page and return it to the IT Department or Your Department Head.

#SS1.6

Employee Name <username@company.com>
IT AUP Policy & Training
To List of all recipients of IT policy with their email addresses showing the company domain.

_Acceptable Usage Policy-1.pdf 333 KB | _Acceptable Usage PolicyArabic.pdf 840 KB | User Acceptance Form.pdf 120 KB

Good Day Gentlemen,

Please find attached our company IT Acceptable use policy document, you'll are kindly requested to go through the document & adhere to the polices that was instructed in the training session that was scheduled on 9th July, 2020 at 10 AM.

All are requested and reminded to understand the users role in protecting the information of our company in order to avoid any disaster.

Your kind cooperation in this regards will be highly appreciated.

Regards,

Company Footer

Company Logo

Saudi Aramco: Confidential

Control #	1	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-1	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must establish, maintain and communicate a Cybersecurity Acceptable Use Policy (AUP) governing the use of Third Party Technology Assets.		
Compliance Analysis and Remarks			

Control Requirements and Compliance Analysis:

1) Obtain/Provide a copy of approved (AUP).

Analysis:

2) Provide sample of communication regarding sharing (AUP) to employees.

Analysis:

3) Provide different versions of approved and communicated AUP, that shows different releases and updates.

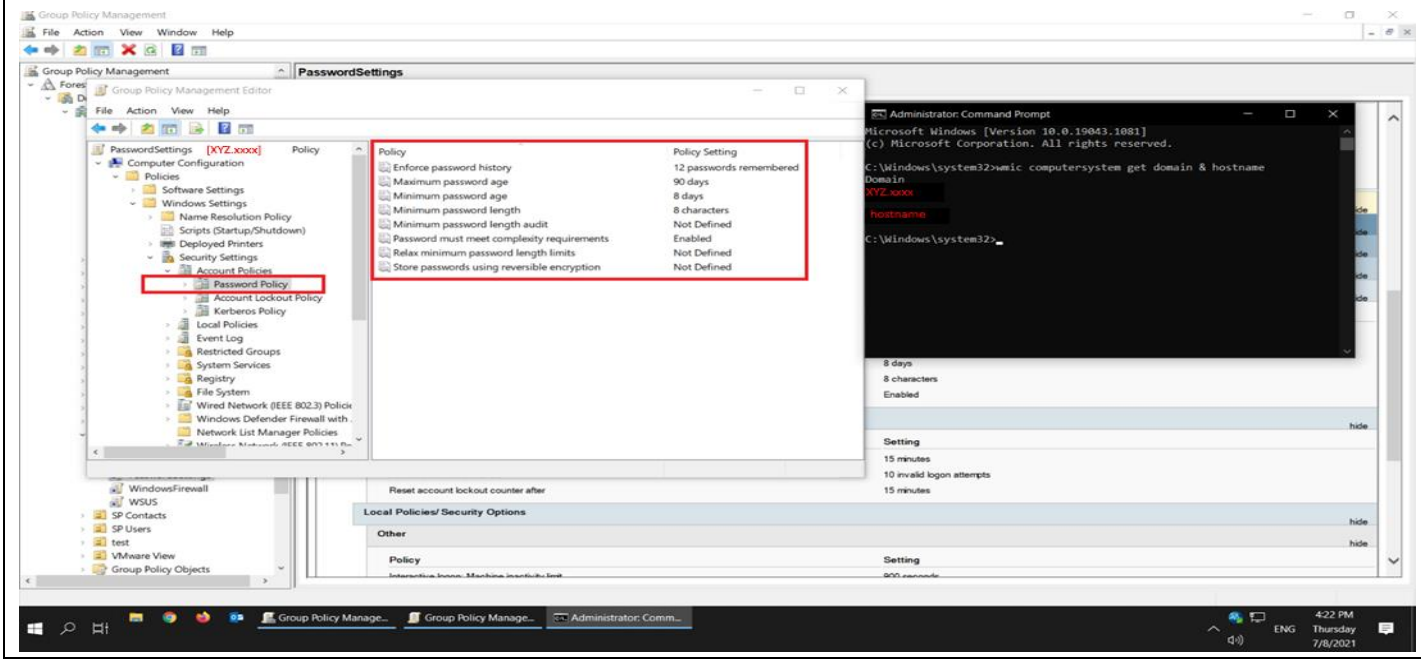
Analysis:

To be filled by audit firm assessors.

Control #	2	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-2	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Password protection measures must be enforced by the Third Party. The following are recommended measures: - Minimum length: 8 alphanumeric characters and special characters. - History: last 12 passwords. - Maximum age: 90 days for login authentication. - Account lockout threshold: 10 invalid login attempts. - Screen saver settings: automatically locked within 15 minutes of inactivity.		
Supporting Evidence			

Evidence from PC, Workstation, Laptop, Servers, Network Devices etc, should be accompanied with command results / information - wmic computersystem get domain / hostname / time in CLI

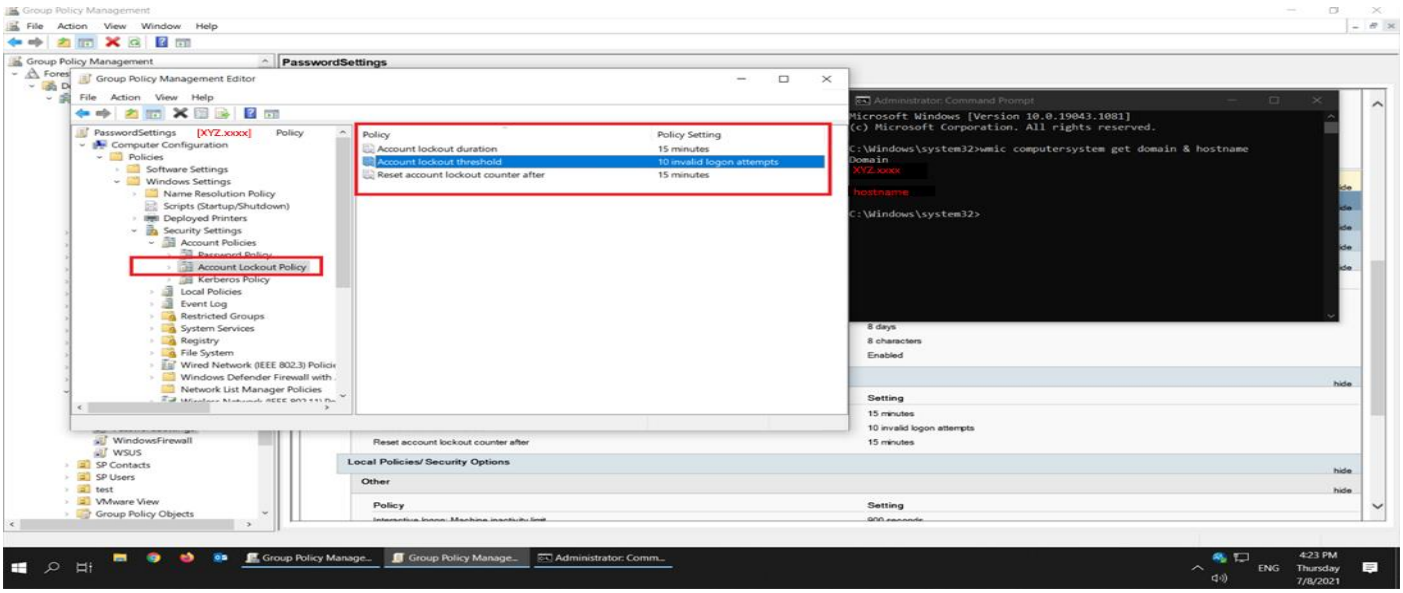
#SS2.1



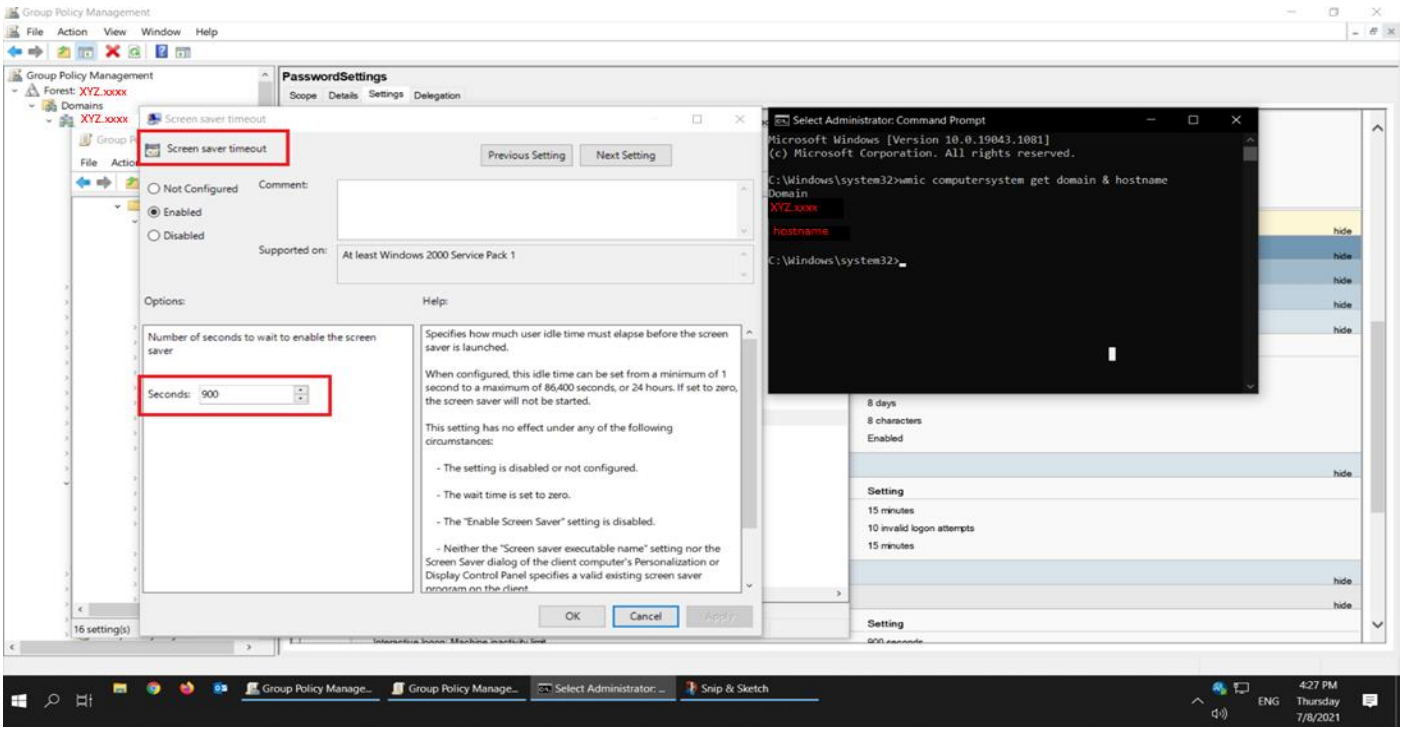
Saudi Aramco: Confidential

Control #	2	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-2	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Password protection measures must be enforced by the Third Party. The following are recommended measures: - Minimum length: 8 alphanumeric characters and special characters. - History: last 12 passwords. - Maximum age: 90 days for login authentication. - Account lockout threshold: 10 invalid login attempts. - Screen saver settings: automatically locked within 15 minutes of inactivity.		

#SS2.2



#SS2.3

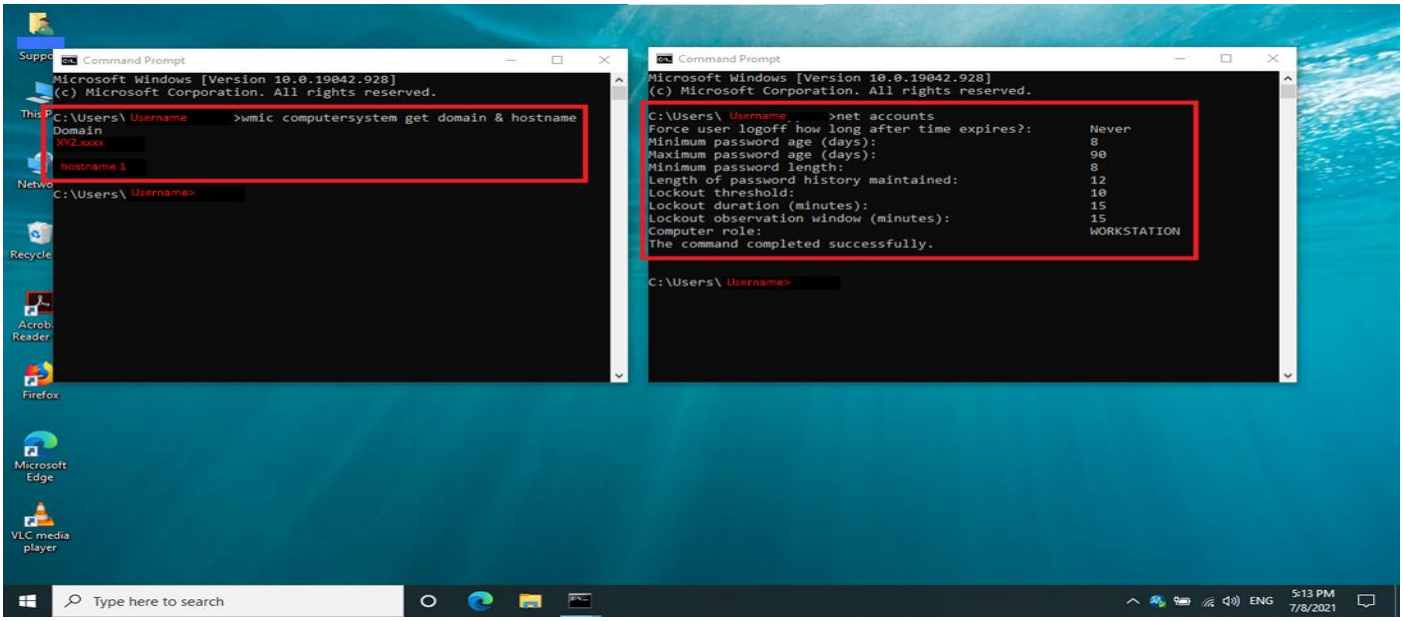


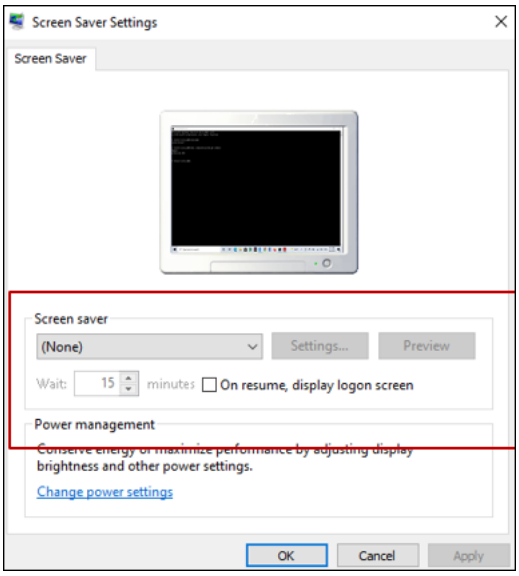
Saudi Aramco: Confidential

Control #	2	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-2	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Password protection measures must be enforced by the Third Party. The following are recommended measures: - Minimum length: 8 alphanumeric characters and special characters. - History: last 12 passwords. - Maximum age: 90 days for login authentication. - Account lockout threshold: 10 invalid login attempts. - Screen saver settings: automatically locked within 15 minutes of inactivity.		

Password policy settings from end point – At least from 3 users:

#SS2.4

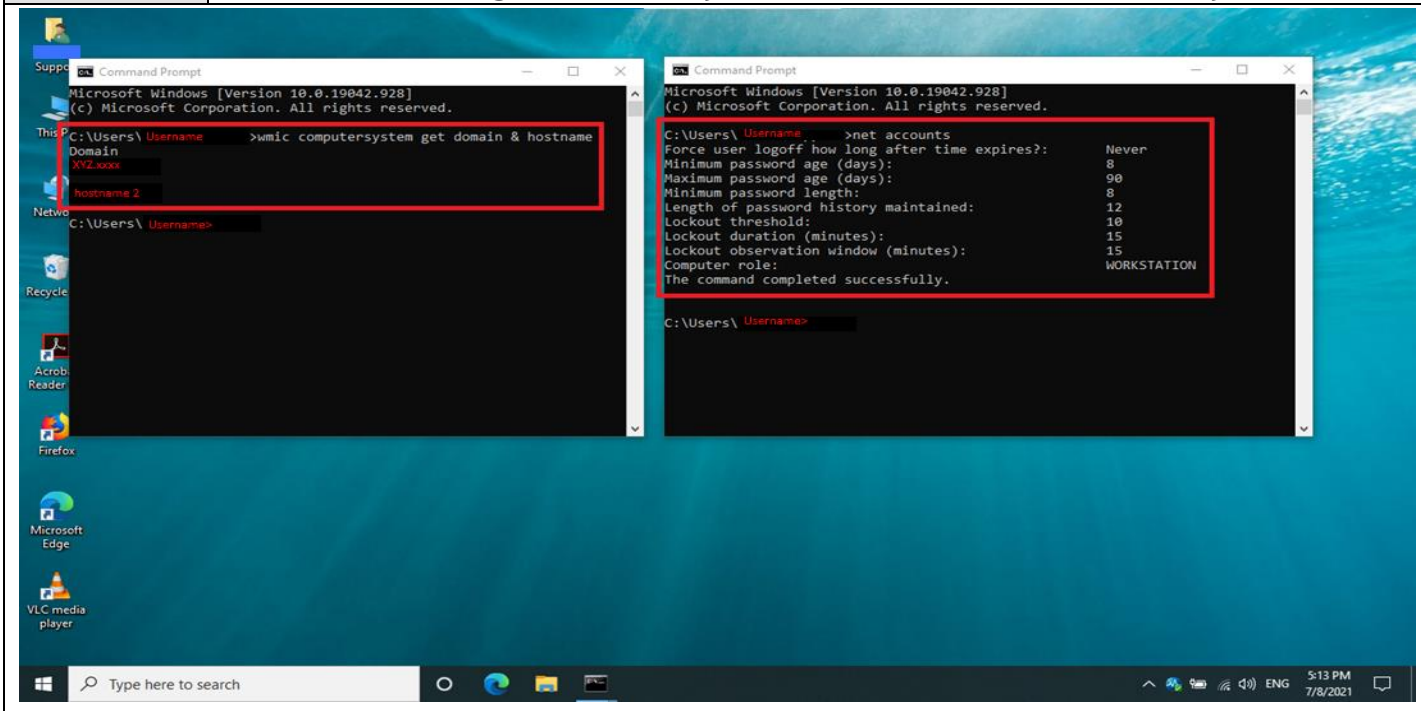


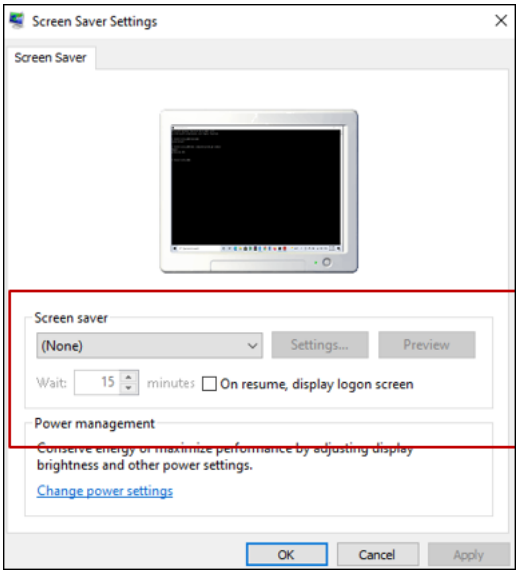


#SS2.5

Saudi Aramco: Confidential

Control #	2	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-2	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Password protection measures must be enforced by the Third Party. The following are recommended measures: - Minimum length: 8 alphanumeric characters and special characters. - History: last 12 passwords. - Maximum age: 90 days for login authentication. - Account lockout threshold: 10 invalid login attempts. - Screen saver settings: automatically locked within 15 minutes of inactivity.		

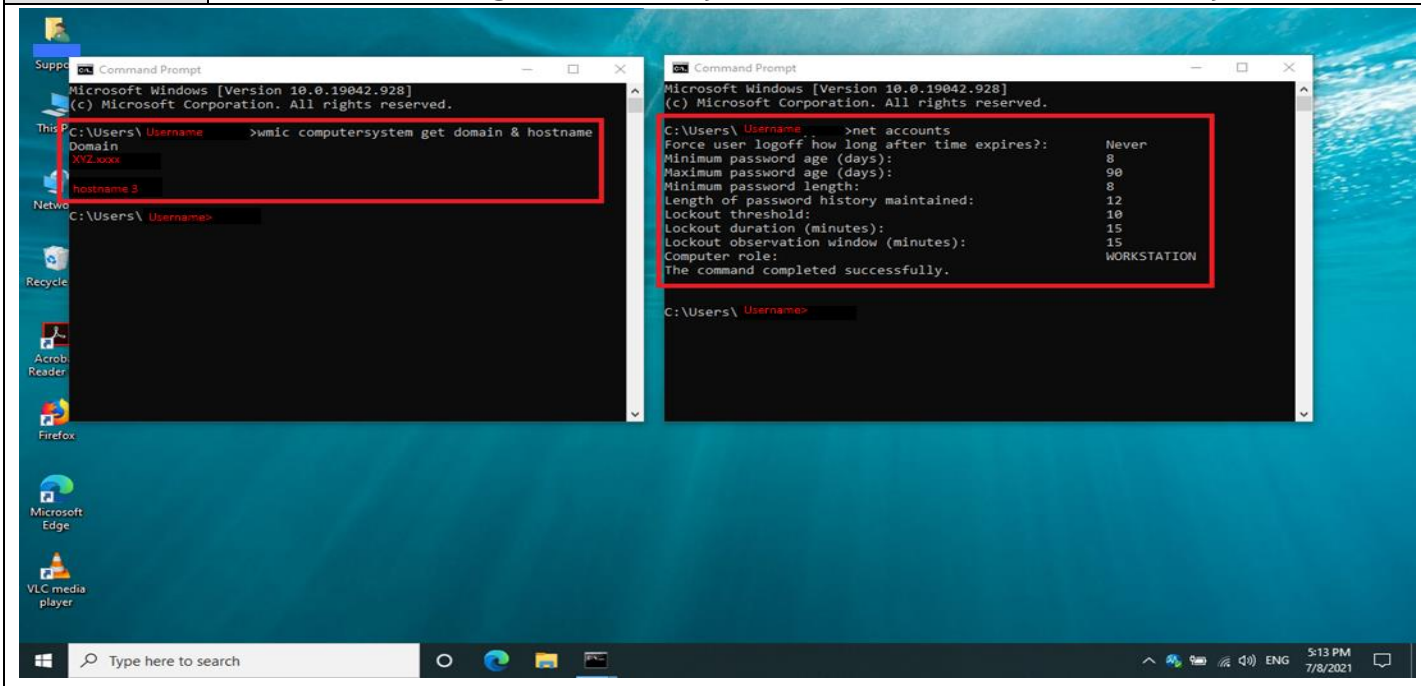


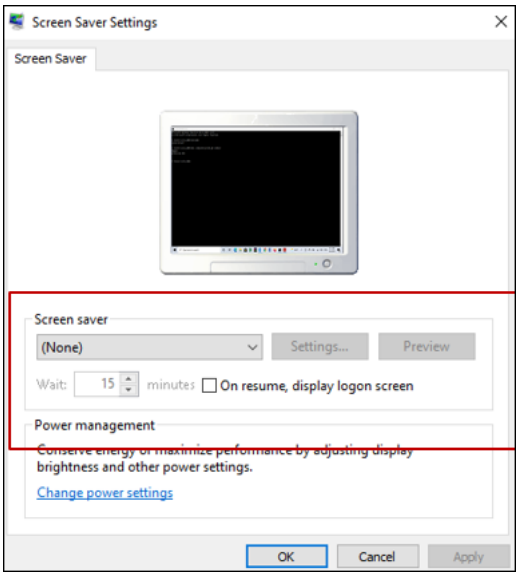


#SS2.6

Saudi Aramco: Confidential

Control #	2	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-2	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Password protection measures must be enforced by the Third Party. The following are recommended measures: - Minimum length: 8 alphanumeric characters and special characters. - History: last 12 passwords. - Maximum age: 90 days for login authentication. - Account lockout threshold: 10 invalid login attempts. - Screen saver settings: automatically locked within 15 minutes of inactivity.		





Compliance Analysis and Remarks

Control Requirements and Compliance Analysis:

1) Perform/provide technical check to confirm the compliance of the control requirements.

Analysis:

Saudi Aramco: Confidential

Control #	2	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-2	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Password protection measures must be enforced by the Third Party. The following are recommended measures: - Minimum length: 8 alphanumeric characters and special characters. - History: last 12 passwords. - Maximum age: 90 days for login authentication. - Account lockout threshold: 10 invalid login attempts. - Screen saver settings: automatically locked within 15 minutes of inactivity.		

2) Check/provide evidence of the password configuration to ensure that default settings are not used.

Analysis:

3) Obtain/provide a copy of password policy that should comply with the control requirements and technical check findings.

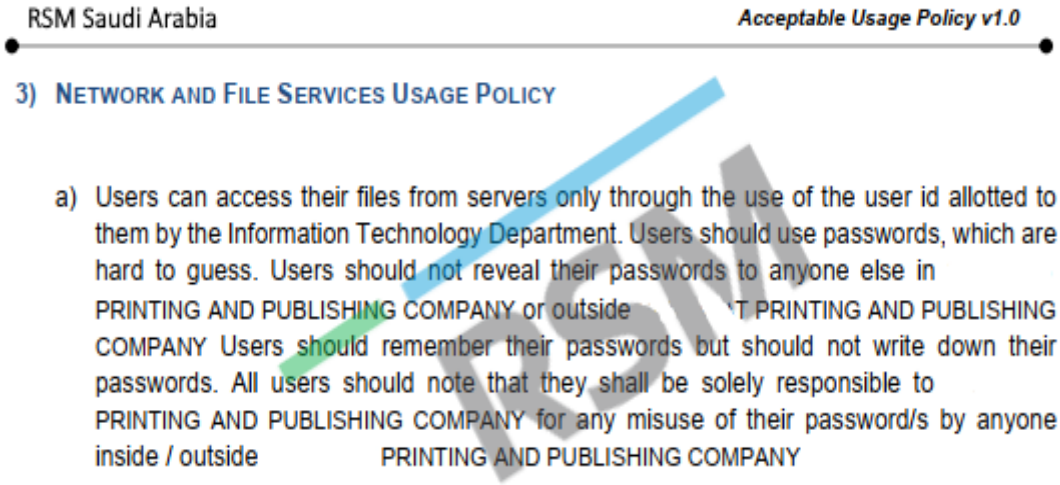
Analysis:

To be filled by audit firm assessors.

Control #	3	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-3	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third party must not write down, electronically store in clear text, or disclose any password or authentication code that is used to access Assets or Critical Facilities. This should be part of Third Party cybersecurity polices.		

Supporting Evidence

#SS3.1



RSM Saudi Arabia *Acceptable Usage Policy v1.0*

3) NETWORK AND FILE SERVICES USAGE POLICY

a) Users can access their files from servers only through the use of the user id allotted to them by the Information Technology Department. Users should use passwords, which are hard to guess. Users should not reveal their passwords to anyone else in PRINTING AND PUBLISHING COMPANY or outside T PRINTING AND PUBLISHING COMPANY Users should remember their passwords but should not write down their passwords. All users should note that they shall be solely responsible to PRINTING AND PUBLISHING COMPANY for any misuse of their password/s by anyone inside / outside PRINTING AND PUBLISHING COMPANY

Compliance Analysis and Remarks

Control Requirement and Compliance Analysis:

1) Obtain/provide a copy of password disclosure policy.

Analysis:

2) Obtain/provide a copy of actions taken in case password disclosure happened part of the consequence management.

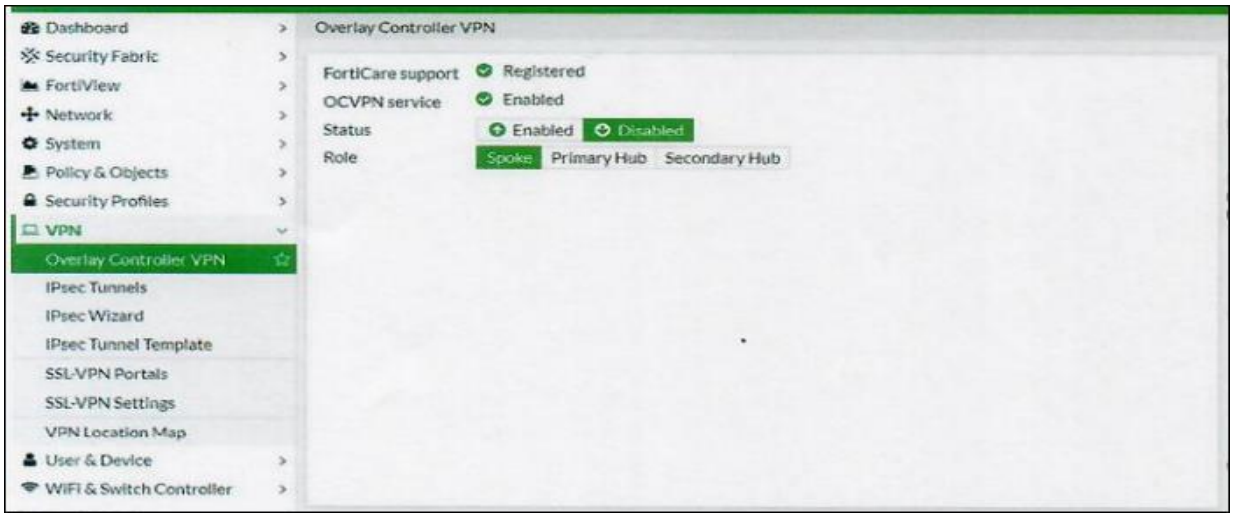
Analysis:

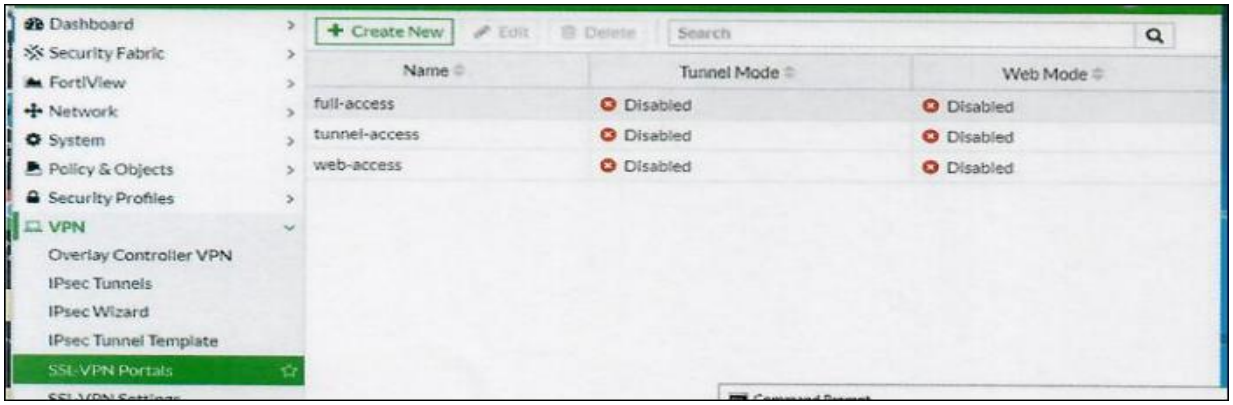
To be filled by audit firm assessors.

Saudi Aramco: Confidential

Control #	4	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-4	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Two-Factor authentication must be enforced on all remote access, including access from the Internet, to Third Party Company computing resources.		
Supporting Evidence			

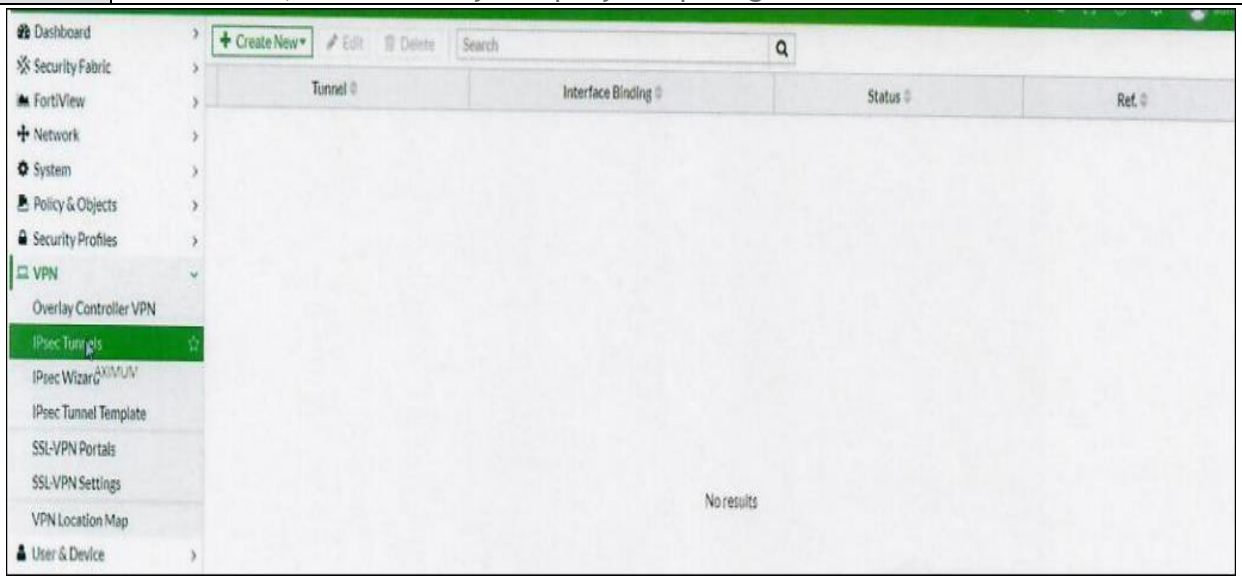
#SS4.1 - (In case VPN is not configured):



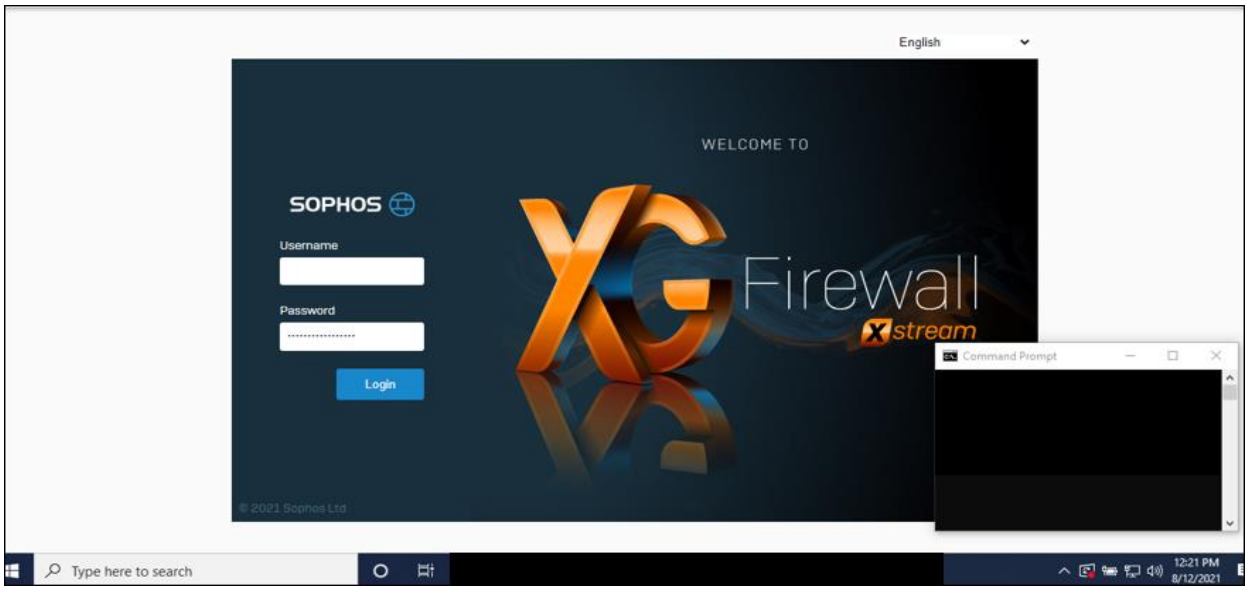


Saudi Aramco: Confidential

Control #	4	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-4	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Two-Factor authentication must be enforced on all remote access, including access from the Internet, to Third Party Company computing resources.		

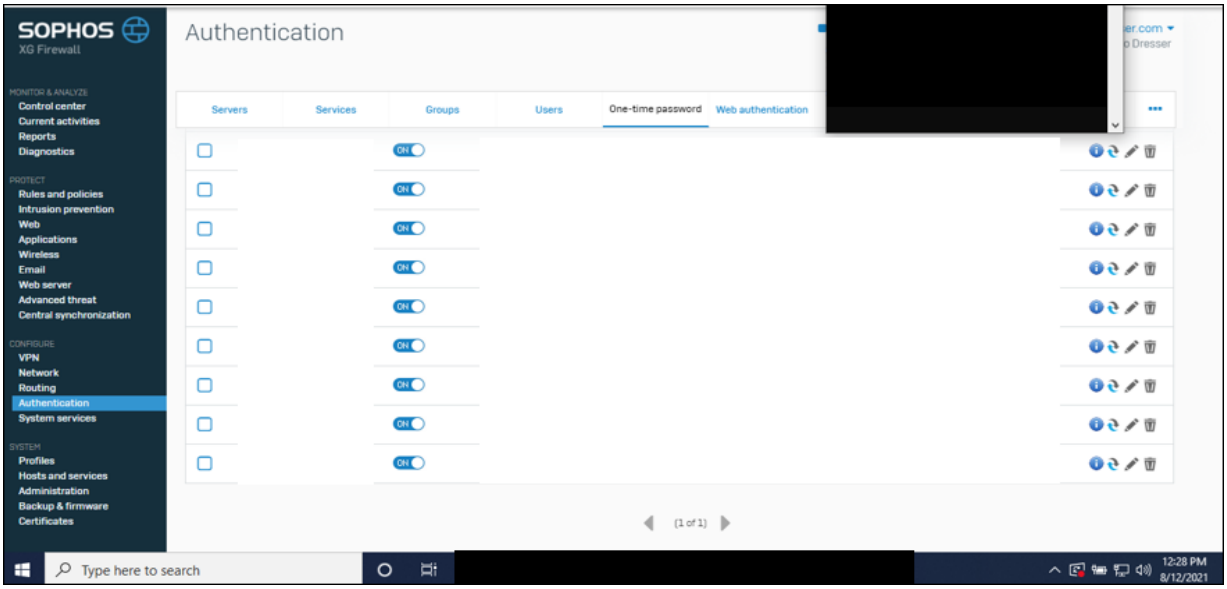


#SS4.2 - (In case VPN is configured):



Saudi Aramco: Confidential

Control #	4	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-4	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Two-Factor authentication must be enforced on all remote access, including access from the Internet, to Third Party Company computing resources.		



Login steps to the VPN – At least from 3 users:



+ Authentication Code

Compliance Analysis and Remarks

Control Requirement and Compliance Analysis:

1) Preform/provide technical check evidence to confirm that strong authentication is in place on remote users' access (e.g., multifactor, strong password parameters). A clear evidence of the Authentication page must be provided.

Analysis:

To be filled by audit firm assessors.

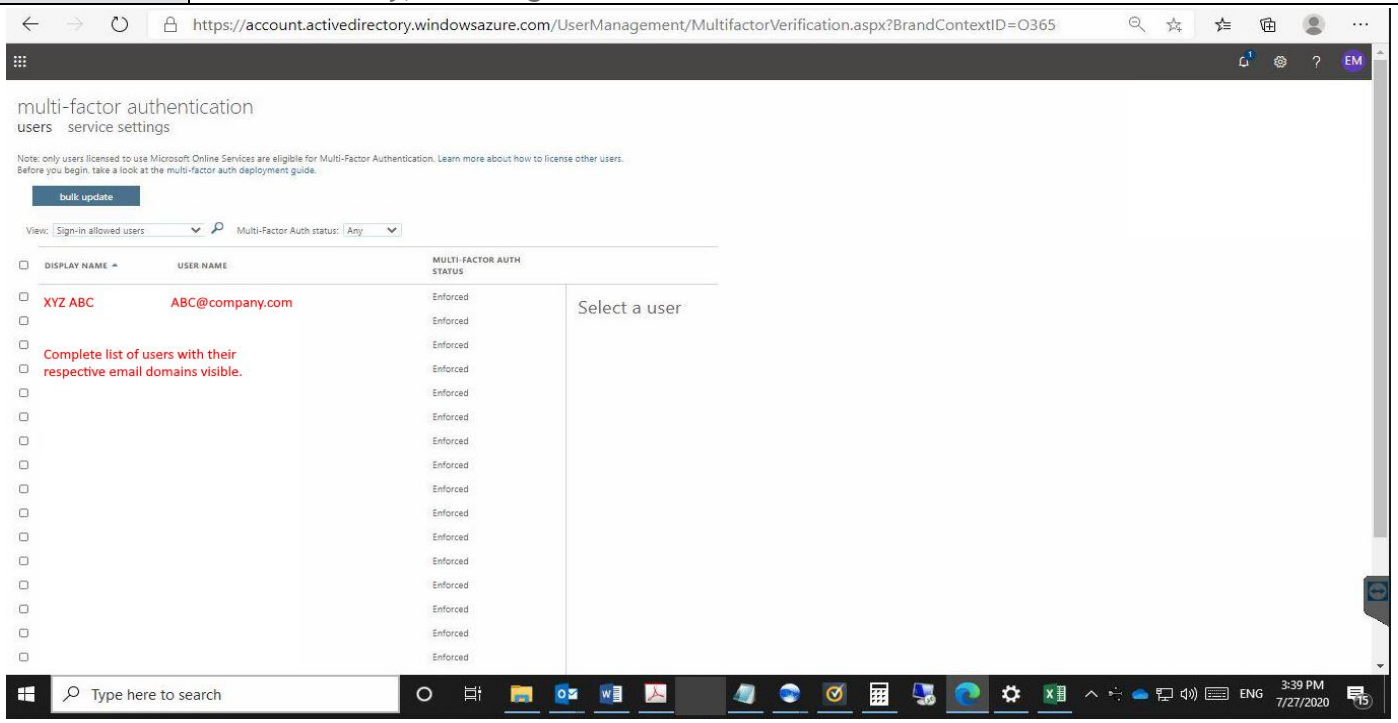
Control #	5	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-5	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Multi-factor authentication must be enforced on all access to Cloud services utilized by the Third Party, including access to cloud-based email.		

Supporting Evidence

#SS5.1

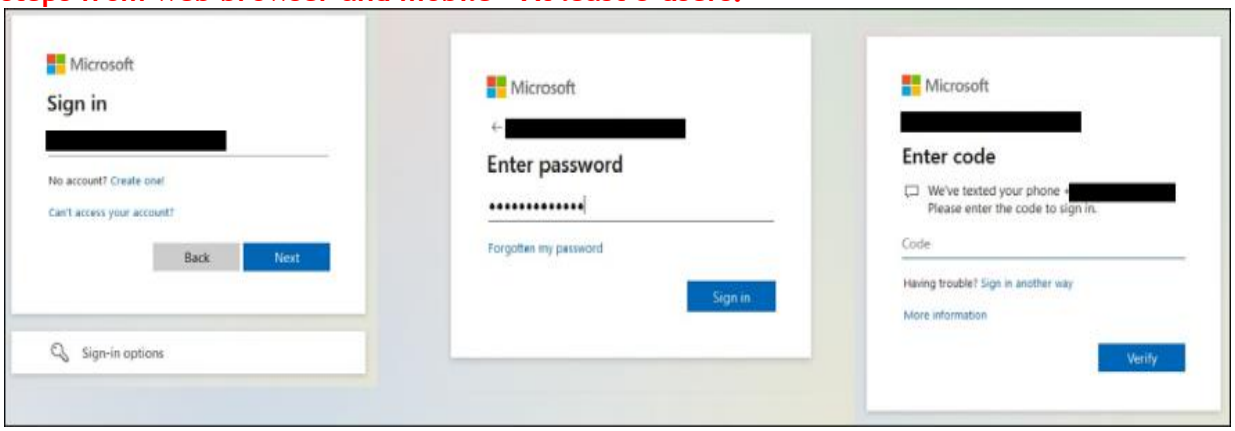
Saudi Aramco: Confidential

Control #	5	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-5	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Multi-factor authentication must be enforced on all access to Cloud services utilized by the Third Party, including access to cloud-based email.		



#SS5.2

Login steps from web browser and mobile – At least 3 users:



Compliance Analysis and Remarks

Control Requirement and Compliance Analysis:

1) Preform/provide technical check evidence to confirm that strong authentication is in place on cloud access (e.g., multifactor, strong password parameters). A clear evidence of the Authentication page must be provided.

Analysis:

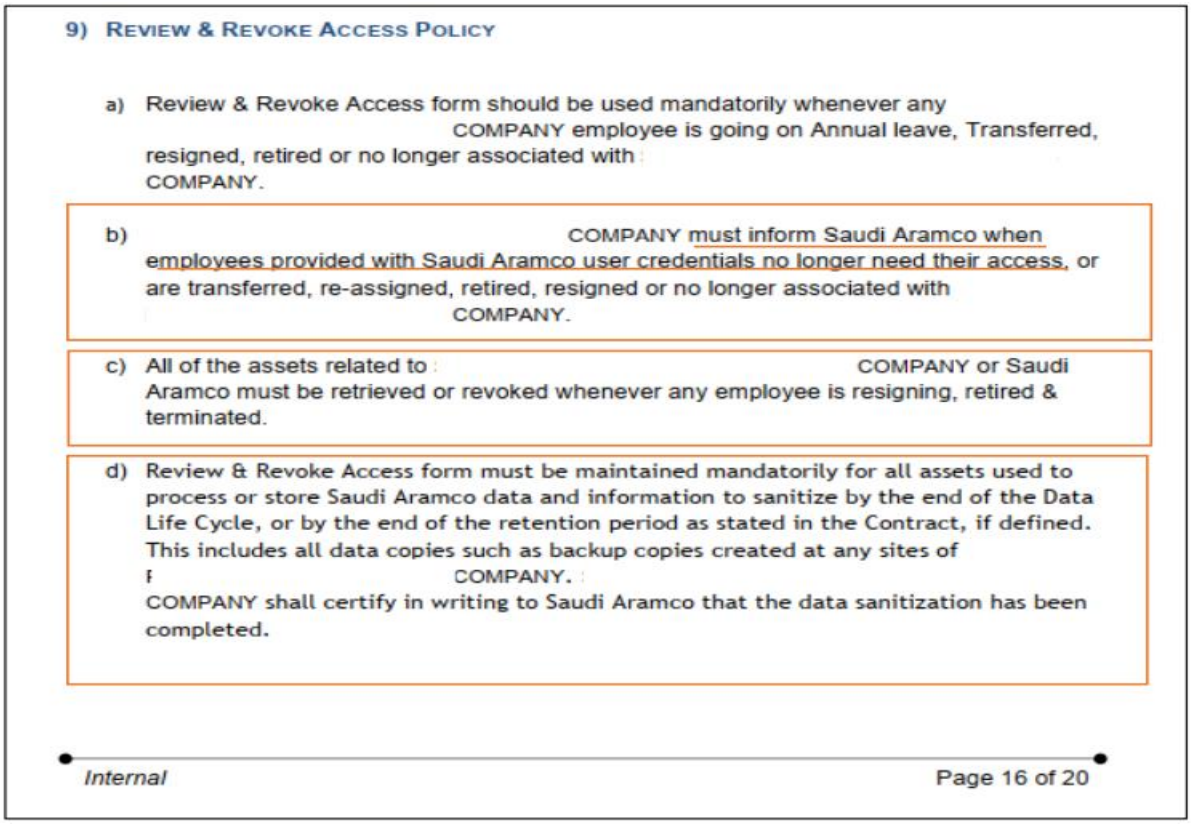
To be filled by audit firm assessors.

Saudi Aramco: Confidential

Control #	6	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-6	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inform Saudi Aramco when employees provided with Saudi Aramco user credentials no longer need their access, or are transferred, re-assigned, retired, resigned or no longer associated with the Third Party.		

Supporting Evidence

#SS6.1



9) REVIEW & REVOKE ACCESS POLICY

a) Review & Revoke Access form should be used mandatorily whenever any COMPANY employee is going on Annual leave, Transferred, resigned, retired or no longer associated with COMPANY.

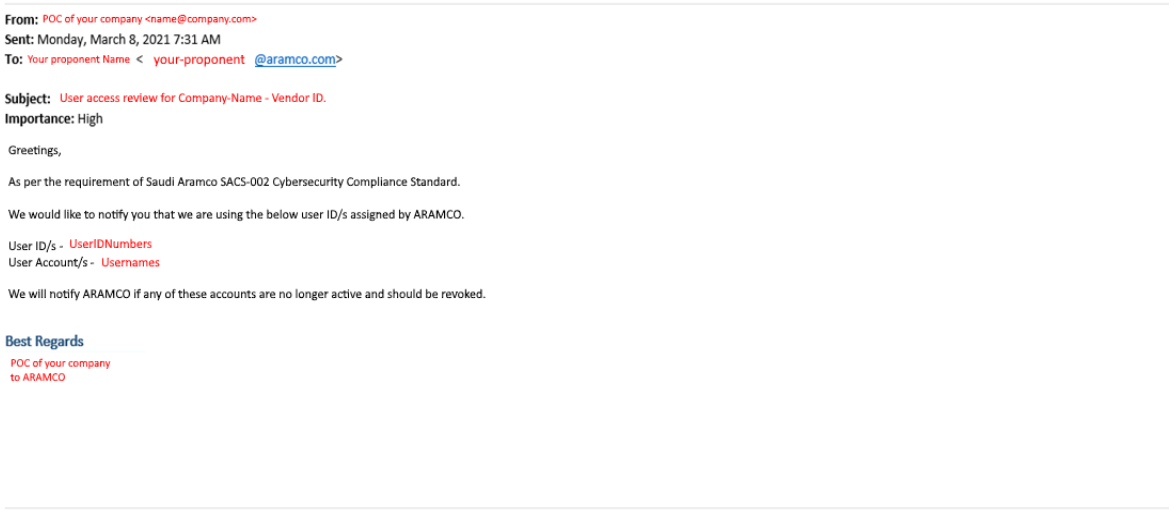
b) COMPANY must inform Saudi Aramco when employees provided with Saudi Aramco user credentials no longer need their access, or are transferred, re-assigned, retired, resigned or no longer associated with COMPANY.

c) All of the assets related to COMPANY or Saudi Aramco must be retrieved or revoked whenever any employee is resigning, retired & terminated.

d) Review & Revoke Access form must be maintained mandatorily for all assets used to process or store Saudi Aramco data and information to sanitize by the end of the Data Life Cycle, or by the end of the retention period as stated in the Contract, if defined. This includes all data copies such as backup copies created at any sites of COMPANY.
COMPANY shall certify in writing to Saudi Aramco that the data sanitization has been completed.

Internal Page 16 of 20

#SS6.2



From: POC of your company <name@company.com>
Sent: Monday, March 8, 2021 7:31 AM
To: Your proponent Name < your-proponent @aramco.com>

Subject: User access review for Company-Name - Vendor ID.
Importance: High

Greetings,

As per the requirement of Saudi Aramco SACS-002 Cybersecurity Compliance Standard.

We would like to notify you that we are using the below user ID/s assigned by ARAMCO.

User ID/s - UserIDNumbers
User Account/s - Usernames

We will notify ARAMCO if any of these accounts are no longer active and should be revoked.

Best Regards
POC of your company
to ARAMCO

Compliance Analysis and Remarks

Saudi Aramco: Confidential

Control #	6	**Compliance Status**	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-6	**Source**	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inform Saudi Aramco when employees provided with Saudi Aramco user credentials no longer need their access, or are transferred, re-assigned, retired, resigned or no longer associated with the Third Party.		
Control Requirements and Compliance Analysis: 1) Review/provide the third-party policy/contract in term of dealing with Saudi Aramco credentials. **Analysis:** 2) Provide a sample of communication (Email) to Saudi Aramco to revoke invalid accounts. **Analysis:** 3) Provide evidence for revoked accounts that are invalid accounts for people who are retired, resigned or no longer associated with the Third Party. **Analysis:** **To be filled by audit firm assessors.**			

Control #	7	**Compliance Status**	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-7	**Source**	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must require all information systems users to take a yearly mandatory Cybersecurity training that addresses acceptable use and good computing practices. Training must address the following topics: 1. Internet and social media security 2. Cybersecurity Acceptable Use 3. Social Engineering and phishing emails 4. Sharing credentials (i.e. username and password) 5. Data Security		
Supporting Evidence			
#SS7.1 Cybersecurity Awareness Basics  **#SS7.2**			

Saudi Aramco: Confidential

Control #	7	**Compliance Status**	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-7	**Source**	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must require all information systems users to take a yearly mandatory Cybersecurity training that addresses acceptable use and good computing practices. Training must address the following topics: 1. Internet and social media security 2. Cybersecurity Acceptable Use 3. Social Engineering and phishing emails 4. Sharing credentials (i.e. username and password) 5. Data Security		

Company Letterhead

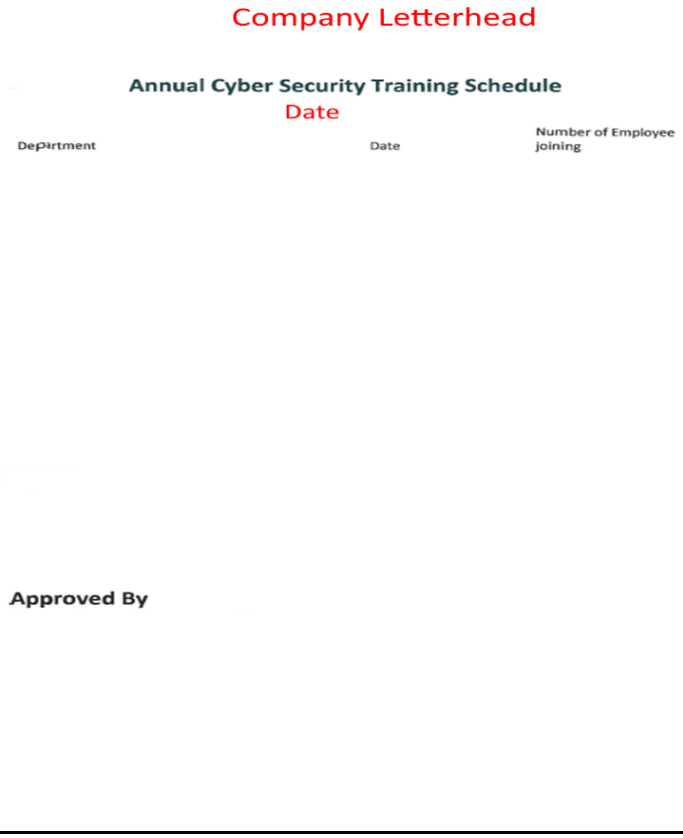
Annual Cyber Security Training Attendance Sheet
Date

SN	Name	Signature
1	Employee Name	Sign
2		
3	List of all employess attending the cybersecurity training.	
4		
5		
6		
7		
8		
9		
10		

#SS7.3

Saudi Aramco: Confidential

Control #	7	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-7	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must require all information systems users to take a yearly mandatory Cybersecurity training that addresses acceptable use and good computing practices. Training must address the following topics: 1. Internet and social media security 2. Cybersecurity Acceptable Use 3. Social Engineering and phishing emails 4. Sharing credentials (i.e. username and password) 5. Data Security		



Company Letterhead

Annual Cyber Security Training Schedule

Date

Department	Date	Number of Employee joining

Approved By

Compliance Analysis and Remarks

Control Requirements and Compliance Analysis:

1) Review/ provide acceptable use policy and/or training materials to ensure content is adequate.

Analysis:

2) Review/ provide user training reports and/or documentation to ensure users are trained in accordance with applicable policy, guidance, and/or requirement (e.g., annual cybersecurity training of all employees).

Analysis:

3) Provide evidences of updating the training materials based on changes in cyber threat environment.

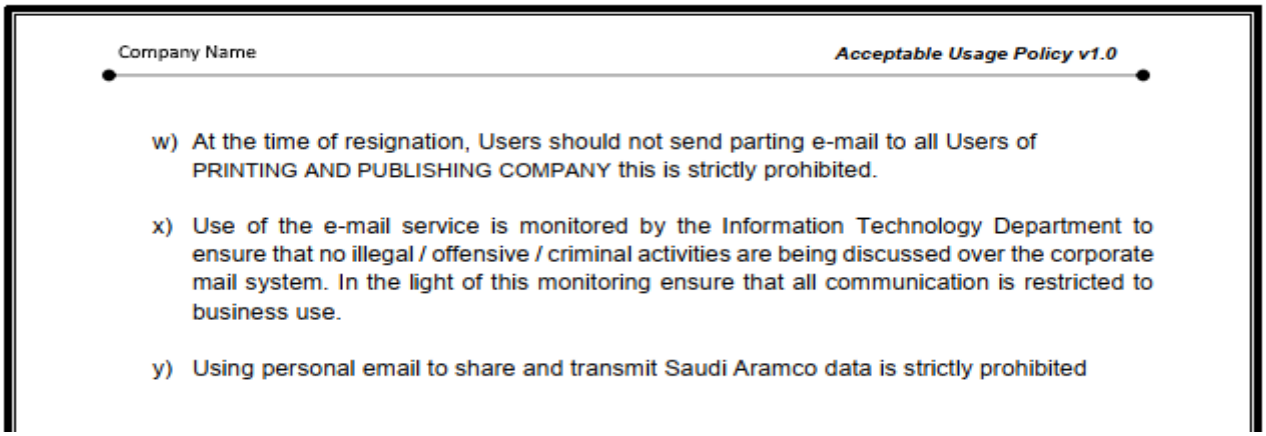
Analysis:

To be filled by audit firm assessors.

Saudi Aramco: Confidential

Control #	8	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-8	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inform personnel, in keeping with Third Party Company Policy, that using personal email to share and transmit Saudi Aramco data is strictly prohibited.		
Supporting Evidence			

#SS8.1



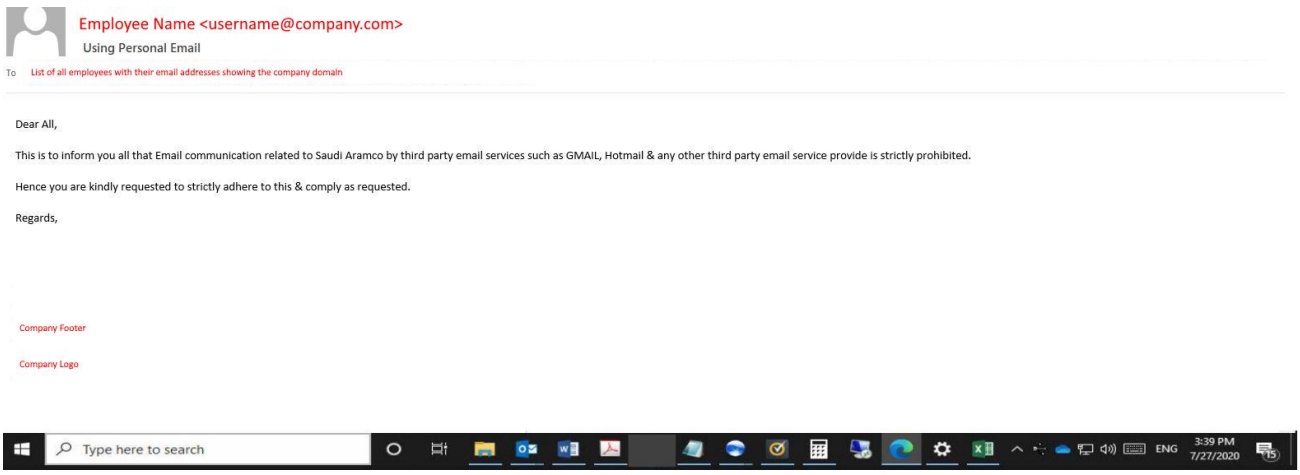
Company Name *Acceptable Usage Policy v1.0*

w) At the time of resignation, Users should not send parting e-mail to all Users of PRINTING AND PUBLISHING COMPANY this is strictly prohibited.

x) Use of the e-mail service is monitored by the Information Technology Department to ensure that no illegal / offensive / criminal activities are being discussed over the corporate mail system. In the light of this monitoring ensure that all communication is restricted to business use.

y) Using personal email to share and transmit Saudi Aramco data is strictly prohibited

#SS8.2



Employee Name <username@company.com>
Using Personal Email
To List of all employees with their email addresses showing the company domain

Dear All,

This is to inform you all that Email communication related to Saudi Aramco by third party email services such as GMAIL, Hotmail & any other third party email service provide is strictly prohibited.

Hence you are kindly requested to strictly adhere to this & comply as requested.

Regards,

Company Footer

Company Logo

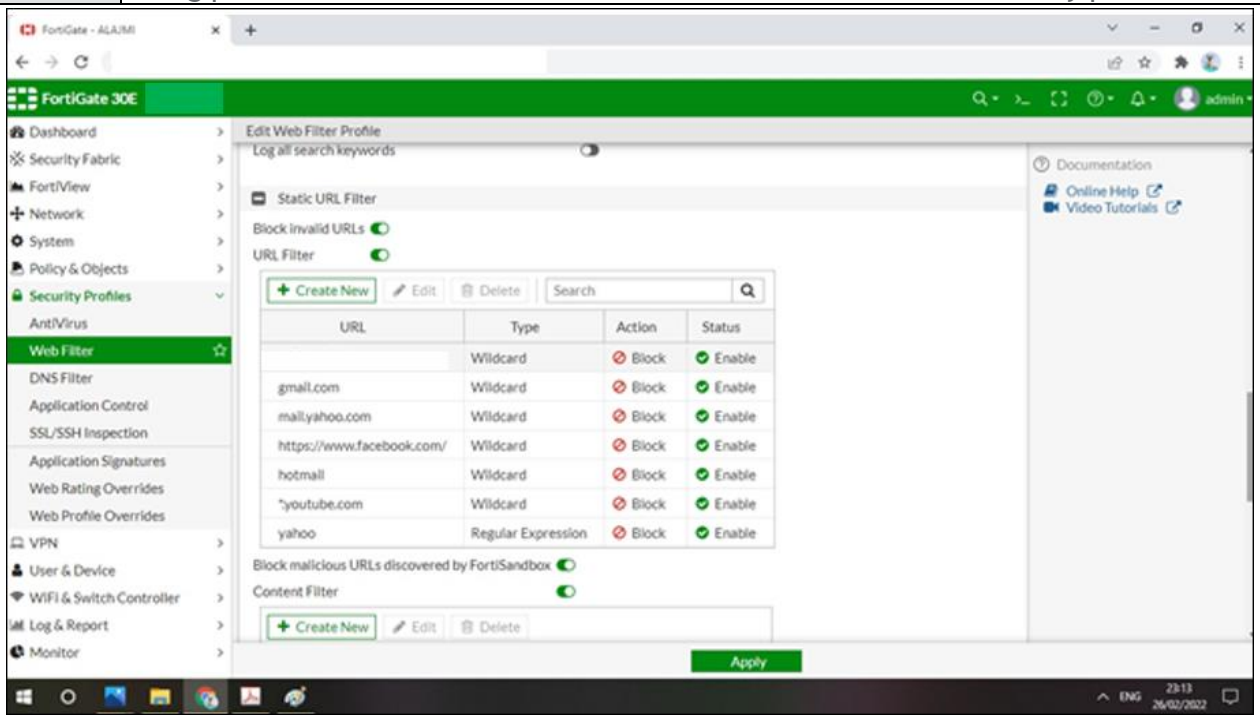
Type here to search ENG 3:39 PM 7/27/2020

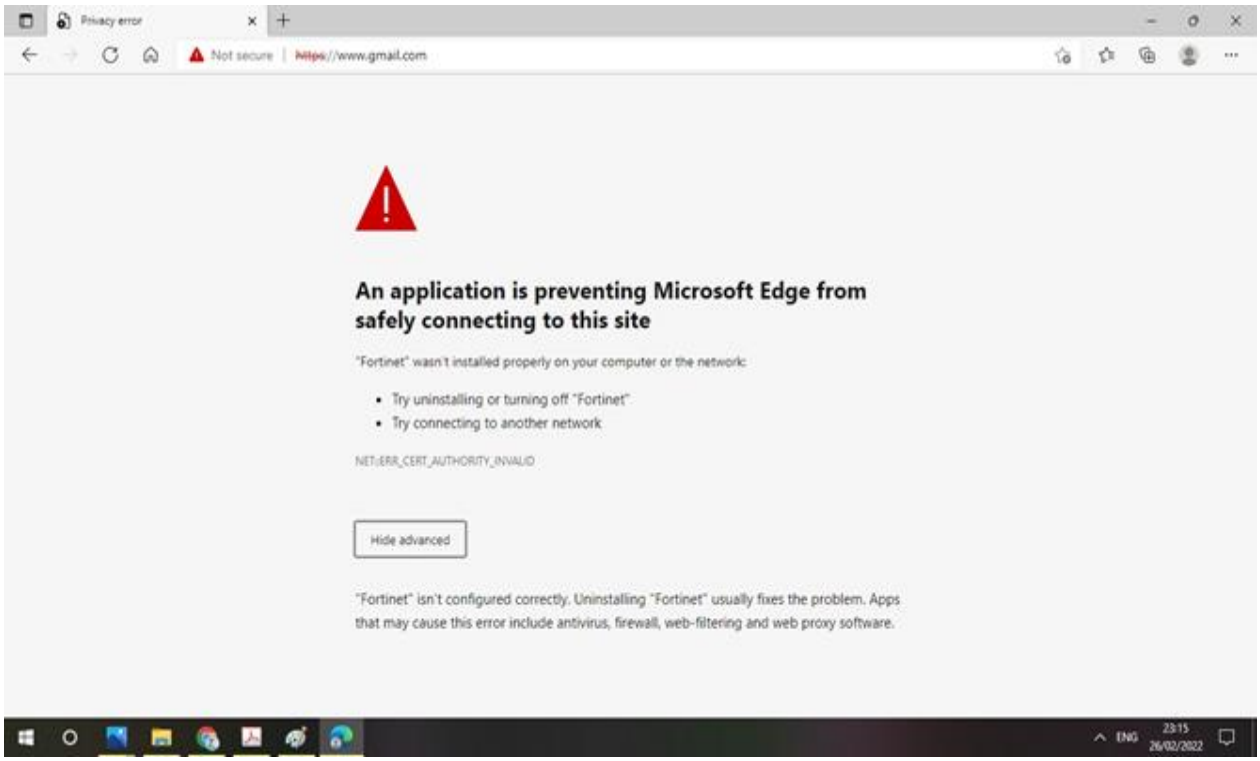
#SS8.3:

Samples of relevant counter measures has taken to comply with the control requirements:

Saudi Aramco: Confidential

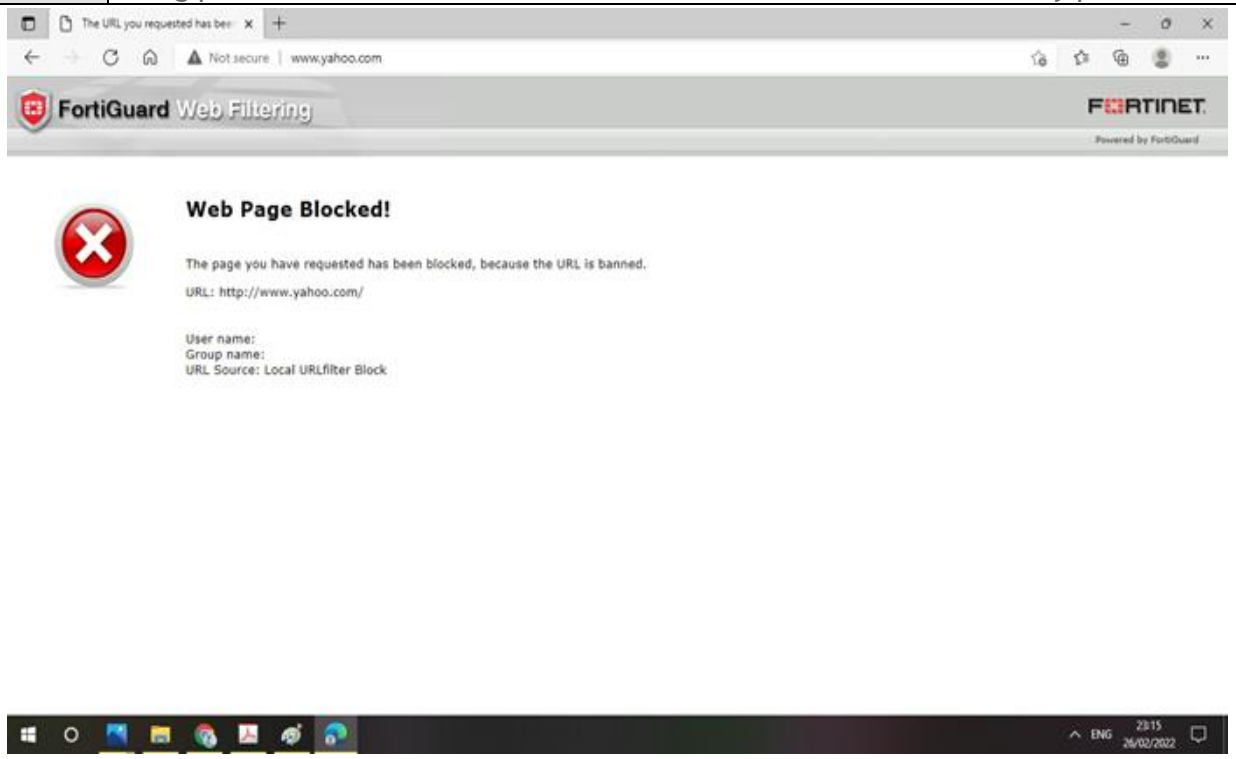
Control #	8	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-8	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inform personnel, in keeping with Third Party Company Policy, that using personal email to share and transmit Saudi Aramco data is strictly prohibited.		

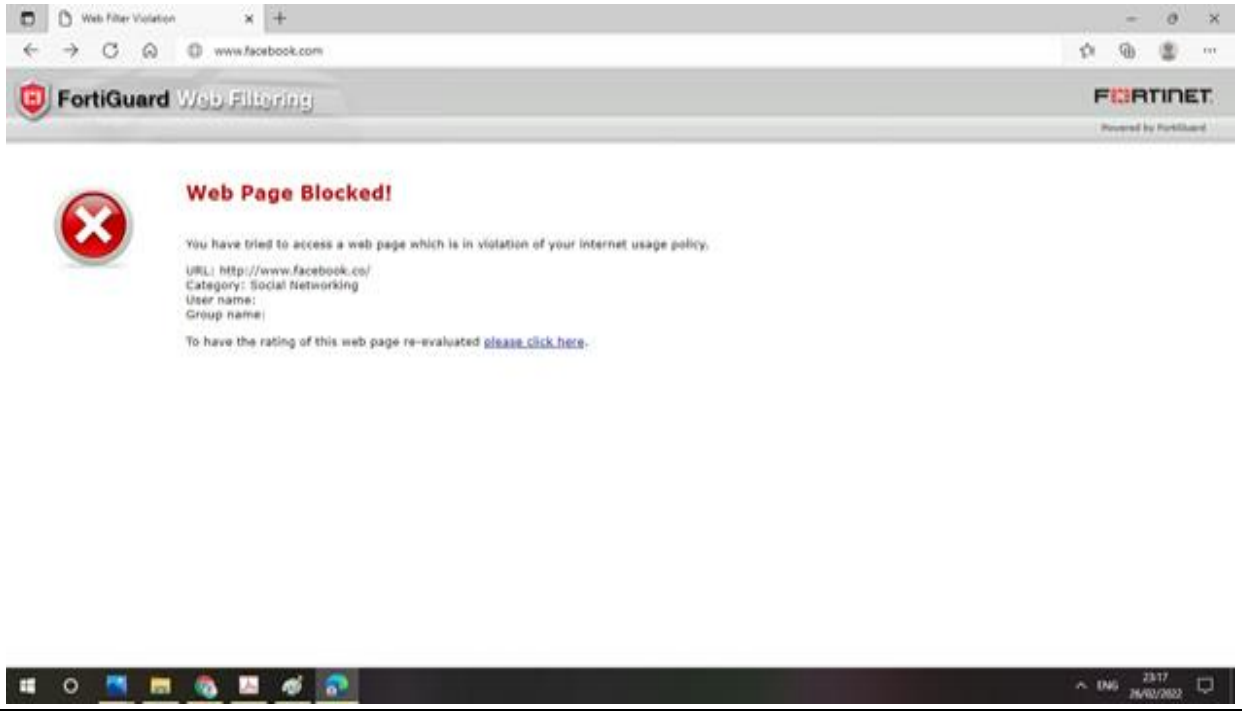




Saudi Aramco: Confidential

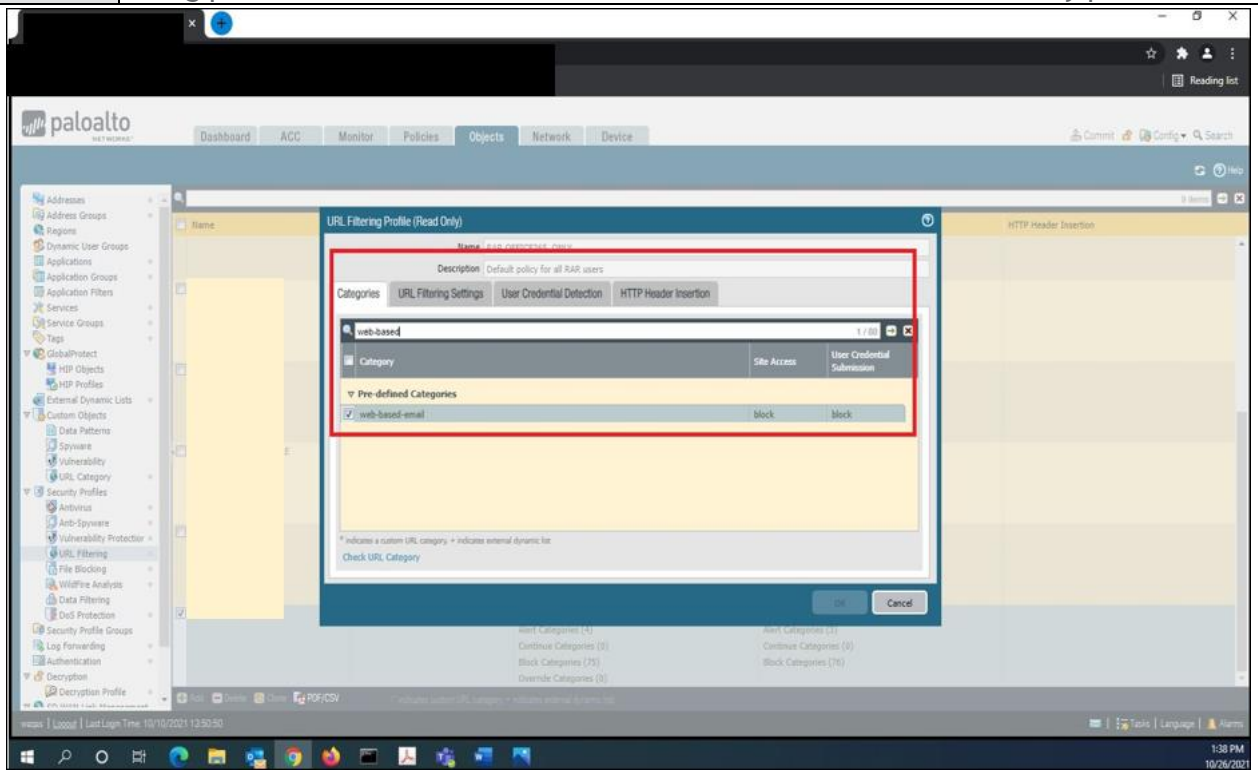
Control #	8	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-8	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inform personnel, in keeping with Third Party Company Policy, that using personal email to share and transmit Saudi Aramco data is strictly prohibited.		

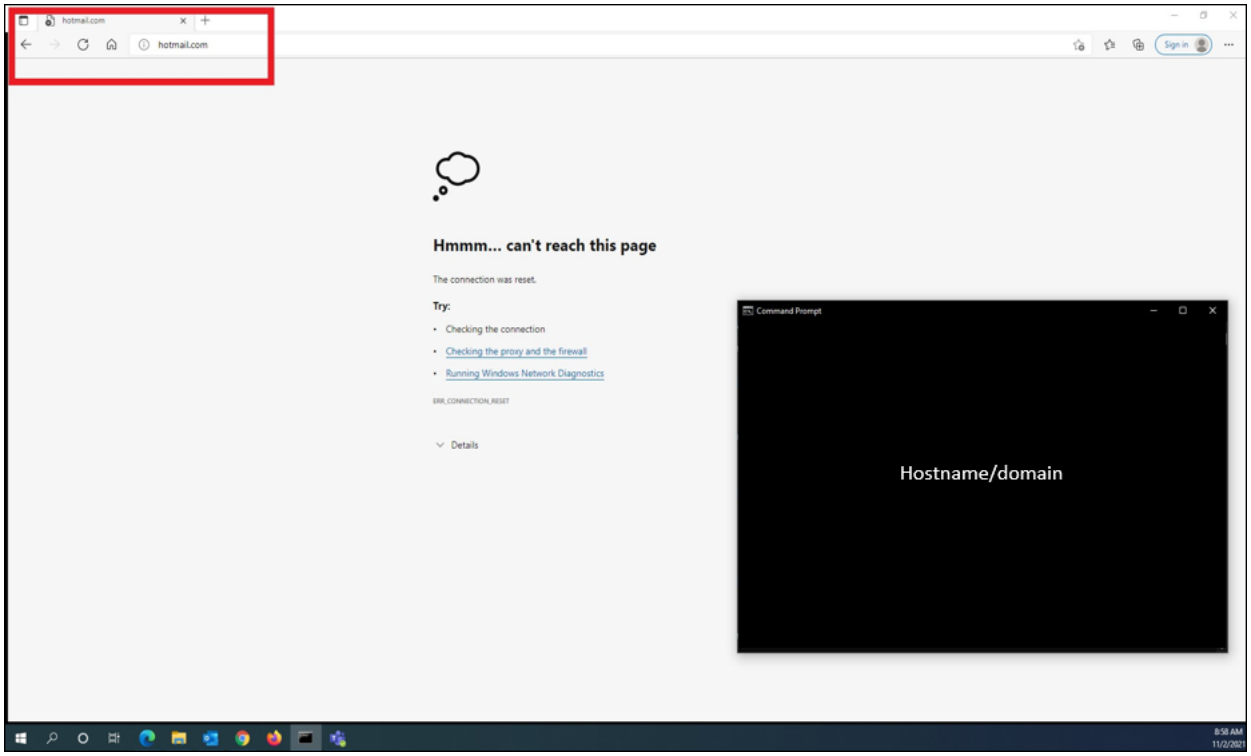




Saudi Aramco: Confidential

Control #	8	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-8	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inform personnel, in keeping with Third Party Company Policy, that using personal email to share and transmit Saudi Aramco data is strictly prohibited.		





Compliance Analysis and Remarks
Control Requirement and Compliance Analysis:

Saudi Aramco: Confidential

Control #	8	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-8	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inform personnel, in keeping with Third Party Company Policy, that using personal email to share and transmit Saudi Aramco data is strictly prohibited.		

1) Review/Provide Third Party Company Policy and contract of using personal email.

Analysis:

2) Provide related emails communicated to third party's employees to ensure the compliance of this control.

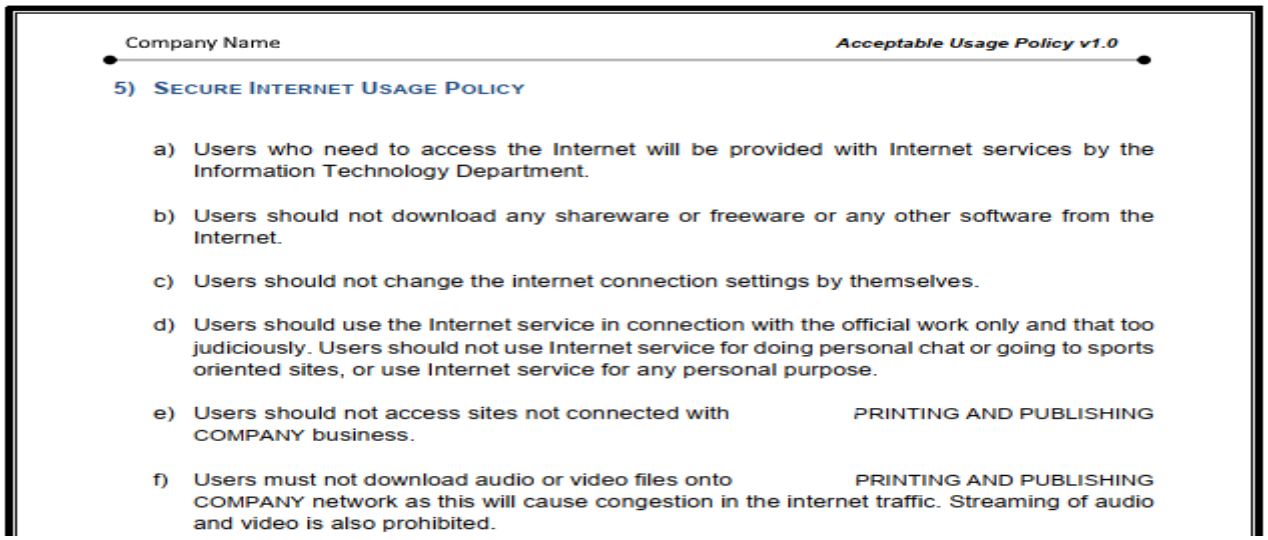
Analysis:

To be filled by audit firm assessors.

Control #	9	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-9	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inform personnel, in keeping with Third Party Company Policy, that disclosing Saudi Aramco policies, procedures and standards or any type of data with unauthorized entities or on the Internet is strictly prohibited.		

Supporting Evidence

#SS 9.1



Company Name *Acceptable Usage Policy v1.0*

5) SECURE INTERNET USAGE POLICY

a) Users who need to access the Internet will be provided with Internet services by the Information Technology Department.

b) Users should not download any shareware or freeware or any other software from the Internet.

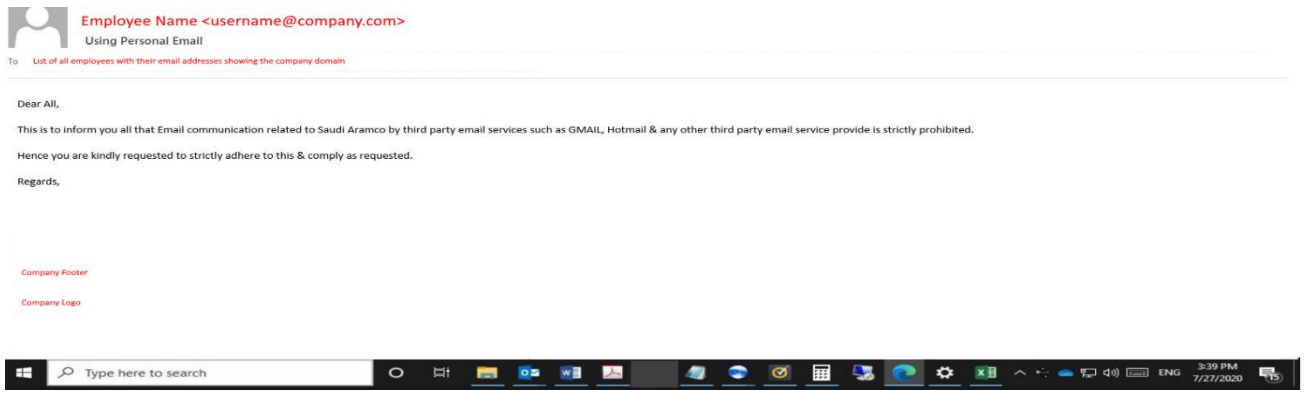
c) Users should not change the internet connection settings by themselves.

d) Users should use the Internet service in connection with the official work only and that too judiciously. Users should not use Internet service for doing personal chat or going to sports oriented sites, or use Internet service for any personal purpose.

e) Users should not access sites not connected with COMPANY business. PRINTING AND PUBLISHING

f) Users must not download audio or video files onto COMPANY network as this will cause congestion in the internet traffic. Streaming of audio and video is also prohibited. PRINTING AND PUBLISHING

#SS9.2



Employee Name <username@company.com>
Using Personal Email

To List of all employees with their email addresses showing the company domain

Dear All,

This is to inform you all that Email communication related to Saudi Aramco by third party email services such as GMAIL, Hotmail & any other third party email service provide is strictly prohibited.

Hence you are kindly requested to strictly adhere to this & comply as requested.

Regards,

Company Footer

Company Logo

Type here to search ENG 3:39 PM 7/27/2020

Saudi Aramco: Confidential

Control #	9	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-9	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inform personnel, in keeping with Third Party Company Policy, that disclosing Saudi Aramco policies, procedures and standards or any type of data with unauthorized entities or on the Internet is strictly prohibited.		
Compliance Analysis and Remarks			

Control Requirements and Compliance Analysis:

1) Review/Provide Third Party policy including contracts and agreements, that highlight the prohibited disclosure of Aramco related data.

Analysis:

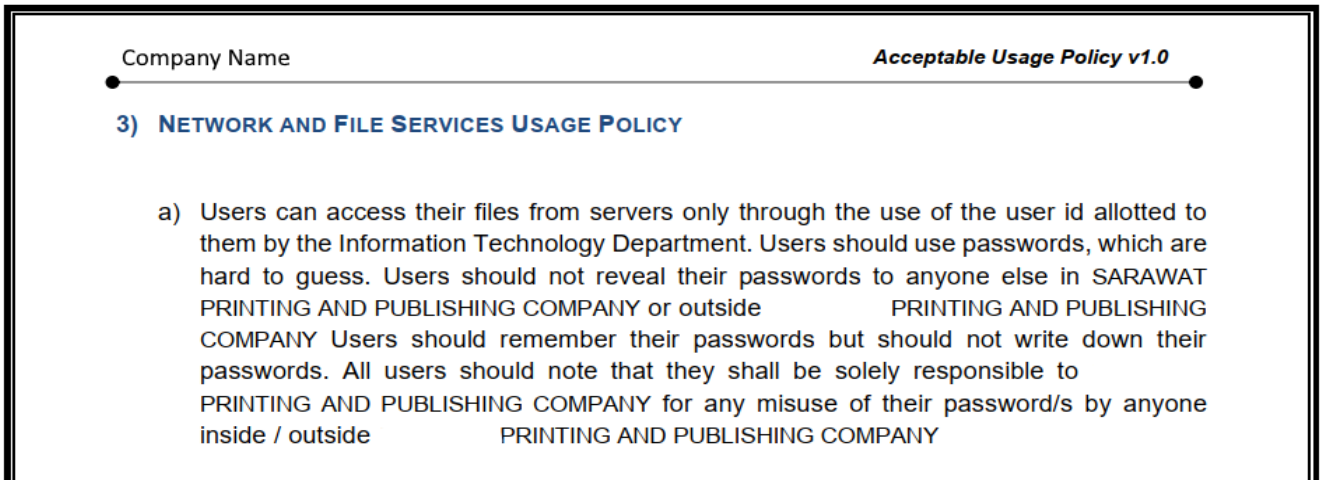
2) Provide related emails communicated to third party's employees to ensure the compliance of this control

Analysis:

To be filled by audit firm assessors.

Control #	10	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-10	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	All Third Party Technology Assets and Systems must be password protected.		
Supporting Evidence			

#SS 10.1



Company Name *Acceptable Usage Policy v1.0*

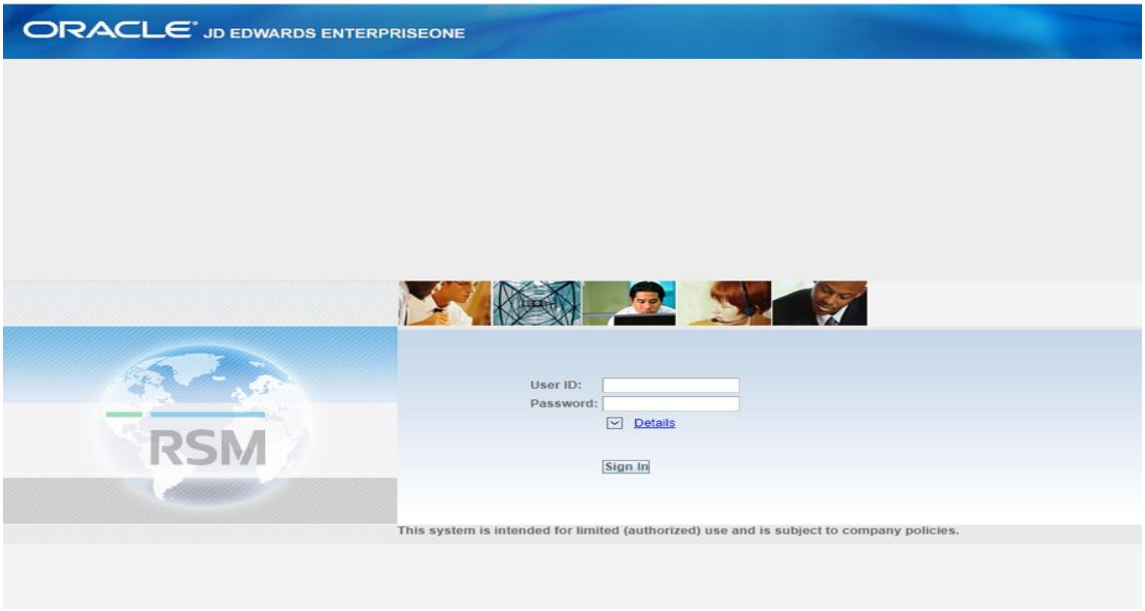
3) NETWORK AND FILE SERVICES USAGE POLICY

a) Users can access their files from servers only through the use of the user id allotted to them by the Information Technology Department. Users should use passwords, which are hard to guess. Users should not reveal their passwords to anyone else in SARAWAT PRINTING AND PUBLISHING COMPANY or outside PRINTING AND PUBLISHING COMPANY Users should remember their passwords but should not write down their passwords. All users should note that they shall be solely responsible to PRINTING AND PUBLISHING COMPANY for any misuse of their password/s by anyone inside / outside PRINTING AND PUBLISHING COMPANY

#SS 10.2

Saudi Aramco: Confidential

Control #	10	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-10	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	All Third Party Technology Assets and Systems must be password protected.		



Compliance Analysis and Remarks

Control Requirement and Compliance Analysis:

1) Provide evidence of related policy for all third party systems to be password protected.

Analysis:

To be filled by audit firm assessors.

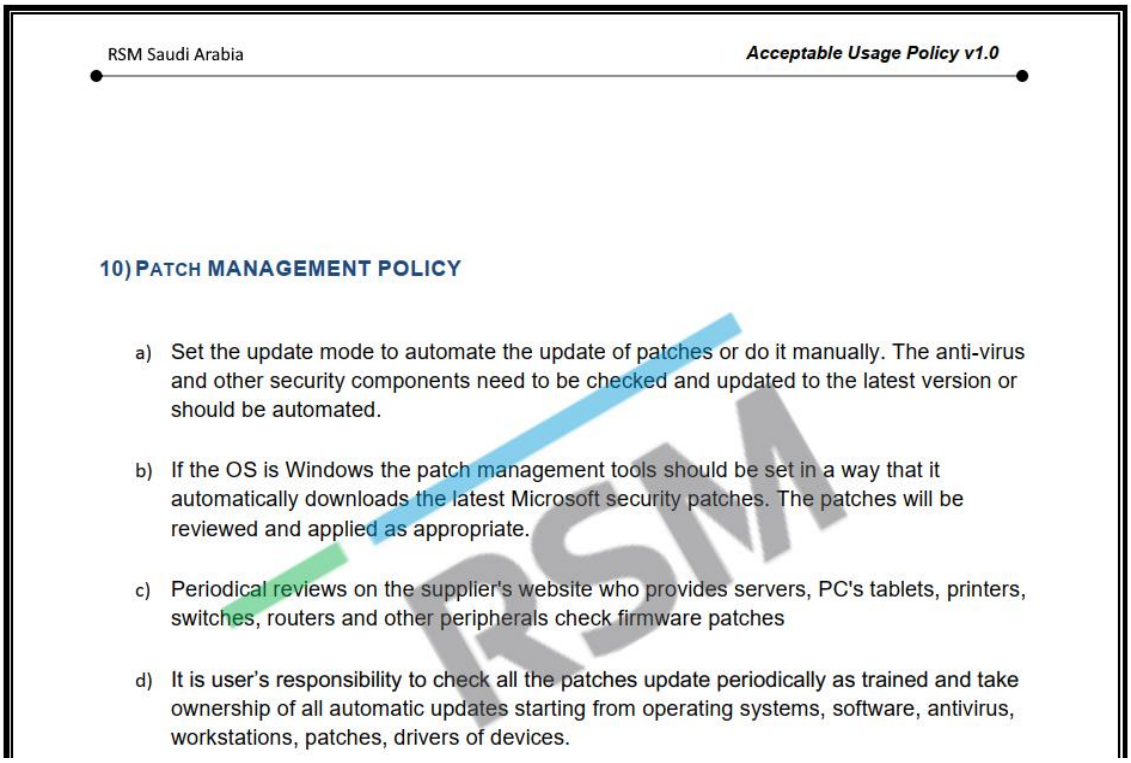
Control #	11	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-11	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party Technology Assets and Systems must be regularly updated with operating system (OS), software and applets patches (i.e. Adobe, Flash, and Java etc.)		

Supporting Evidence

#SS11.1

Saudi Aramco: Confidential

Control #	11	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-11	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party Technology Assets and Systems must be regularly updated with operating system (OS), software and applets patches (i.e. Adobe, Flash, and Java etc.)		



RSM Saudi Arabia *Acceptable Usage Policy v1.0*

10) PATCH MANAGEMENT POLICY

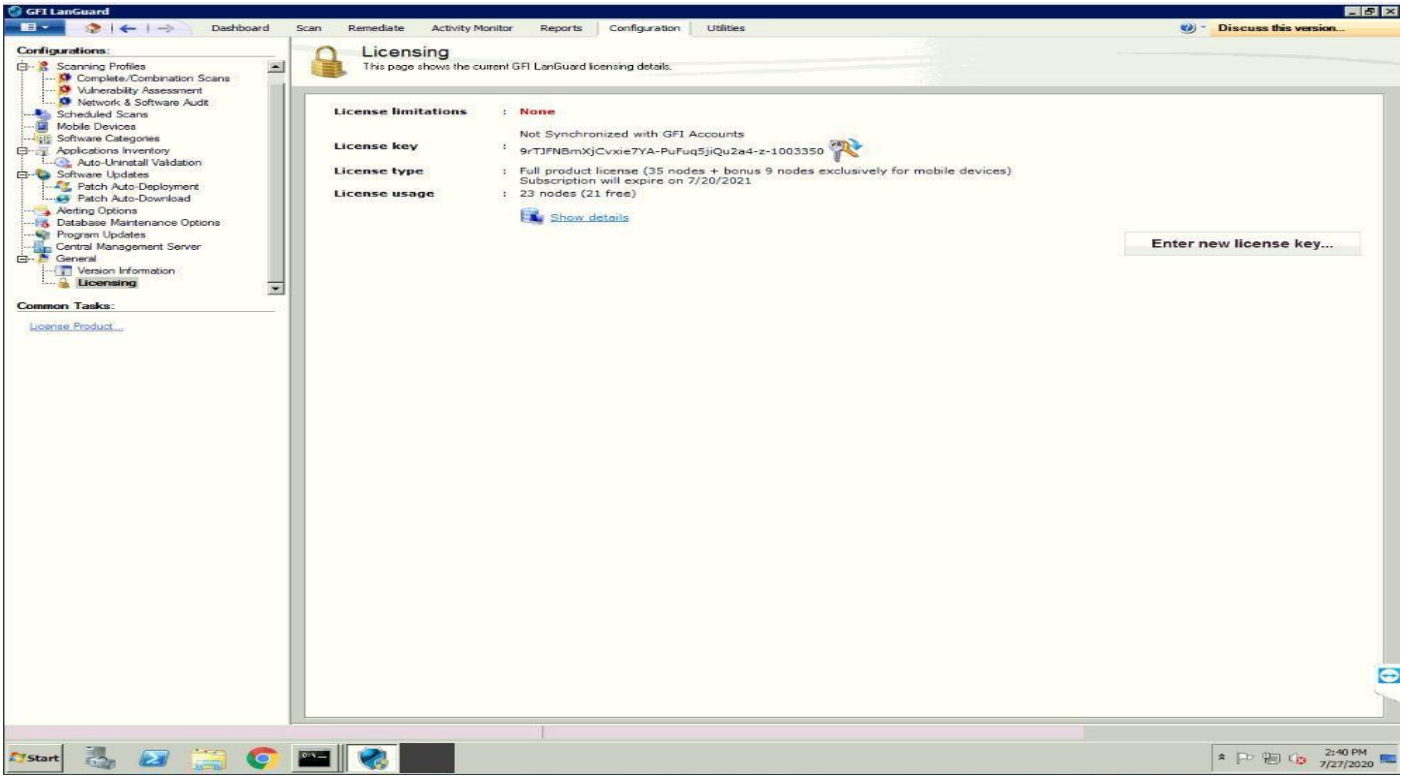
a) Set the update mode to automate the update of patches or do it manually. The anti-virus and other security components need to be checked and updated to the latest version or should be automated.

b) If the OS is Windows the patch management tools should be set in a way that it automatically downloads the latest Microsoft security patches. The patches will be reviewed and applied as appropriate.

c) Periodical reviews on the supplier's website who provides servers, PC's tablets, printers, switches, routers and other peripherals check firmware patches

d) It is user's responsibility to check all the patches update periodically as trained and take ownership of all automatic updates starting from operating systems, software, antivirus, workstations, patches, drivers of devices.

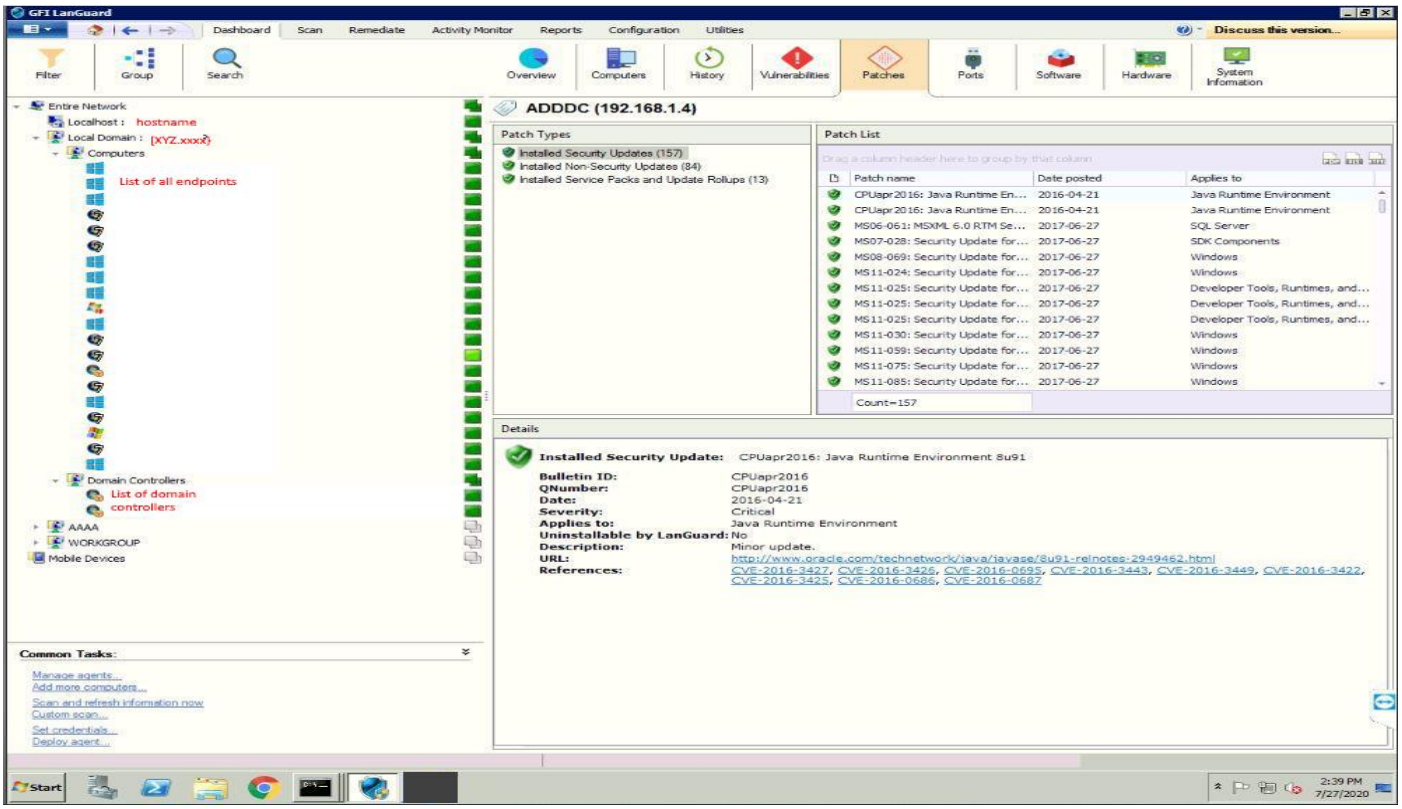
#SS11.2



Saudi Aramco: Confidential

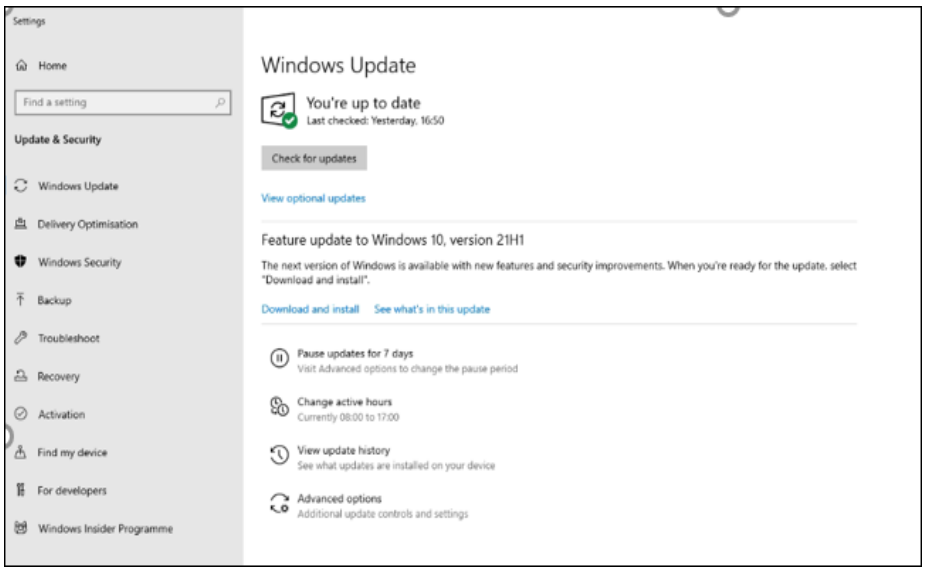
Control #	11	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-11	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party Technology Assets and Systems must be regularly updated with operating system (OS), software and applets patches (i.e. Adobe, Flash, and Java etc.)		

List of users from the centralized solution:



#SS11.2

Widows update from the workstation – At least from 3 users:



Saudi Aramco: Confidential

Control #	11	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-11	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party Technology Assets and Systems must be regularly updated with operating system (OS), software and applets patches (i.e. Adobe, Flash, and Java etc.)		
Compliance Analysis and Remarks			

Control Requirement and Compliance analysis:

1) Provide evidence of patch management policy and procedures.

Analysis:

2) Provide evidence of on sample of workstations to ensure that OS and software are up-to-date.

Analysis:

3) Provide evidence of scheduling and technology used for patch and updates deployment.

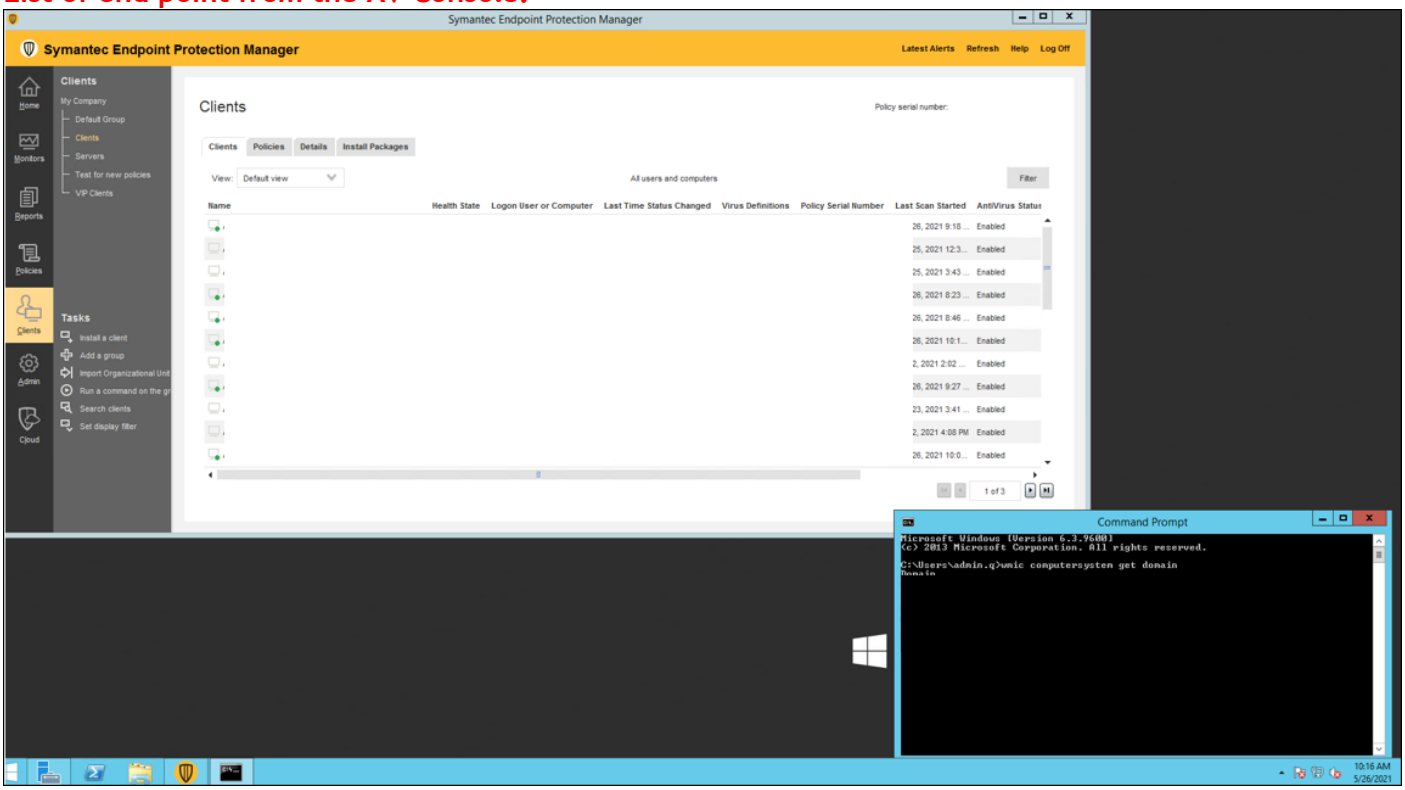
Analysis:

To be filled by audit firm assessors.

Control #	12	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-12	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party Technology Assets must be protected with anti-virus (AV) software. Updates must be applied daily, and full system scans must be performed every two weeks.		
Supporting Evidence			

#SS12.1

List of end point from the AV Console:

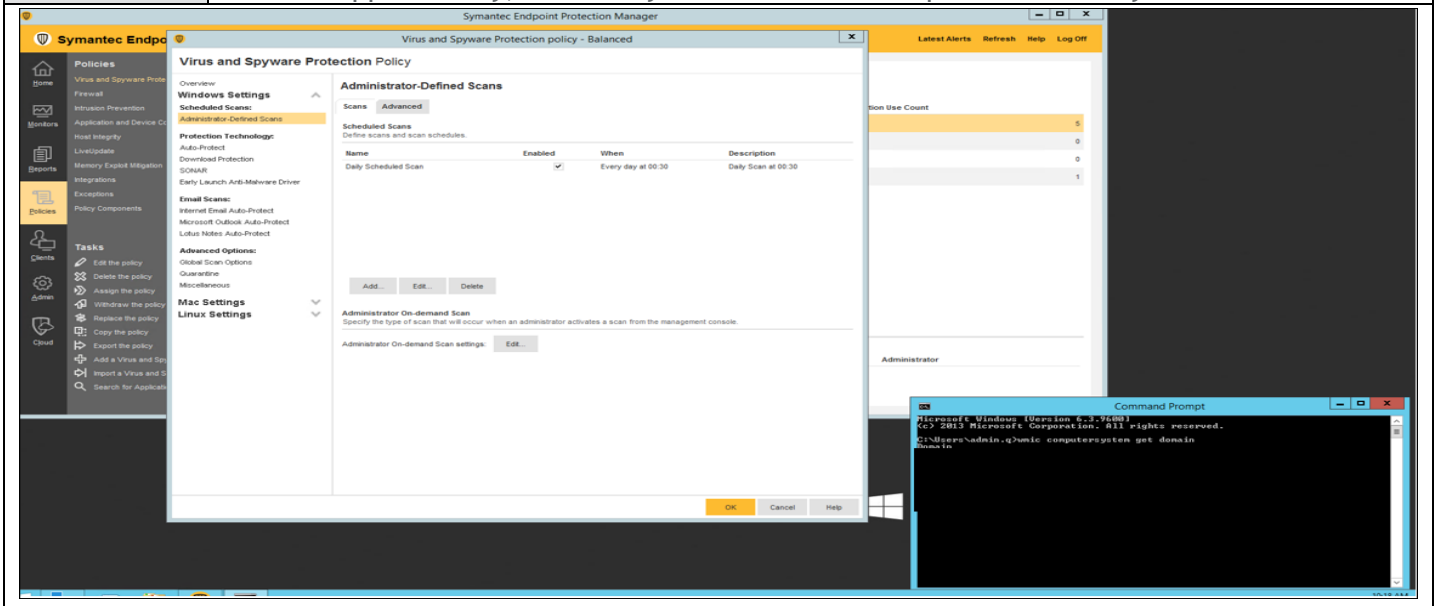


#SS12.2

Scan schedule for all endpoints from the Console:

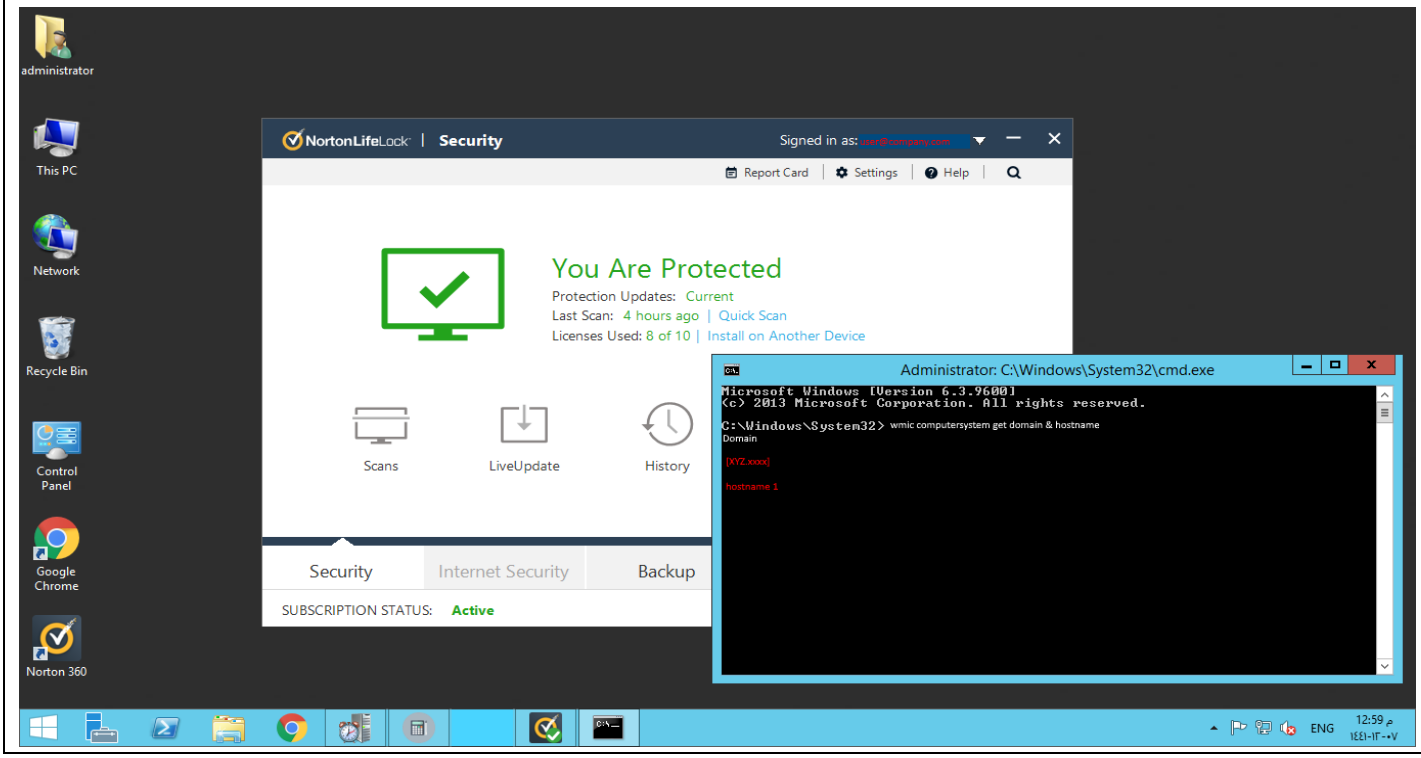
Saudi Aramco: Confidential

Control #	12	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-12	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party Technology Assets must be protected with anti-virus (AV) software. Updates must be applied daily, and full system scans must be performed every two weeks.		



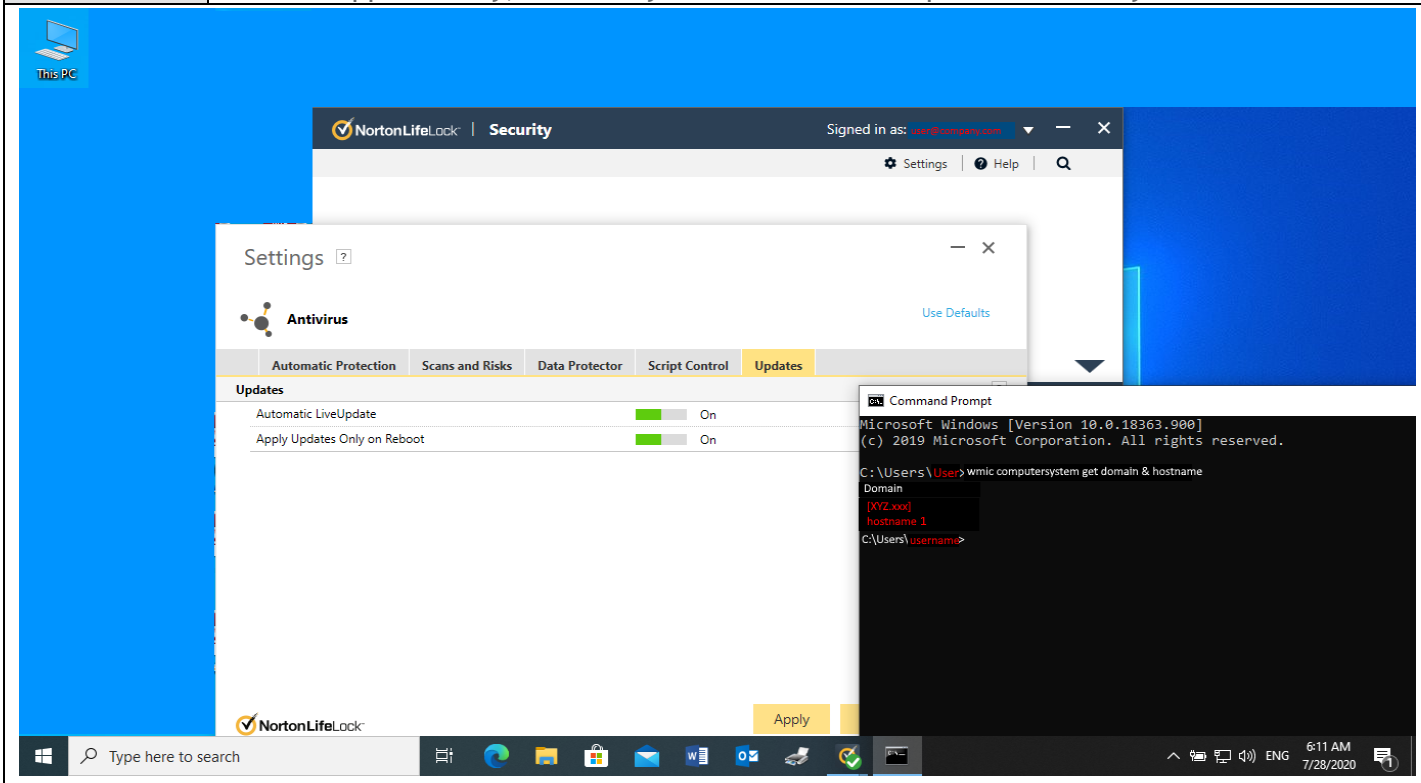
AV status from the workstation – At least from 3 users:

#SS12.3

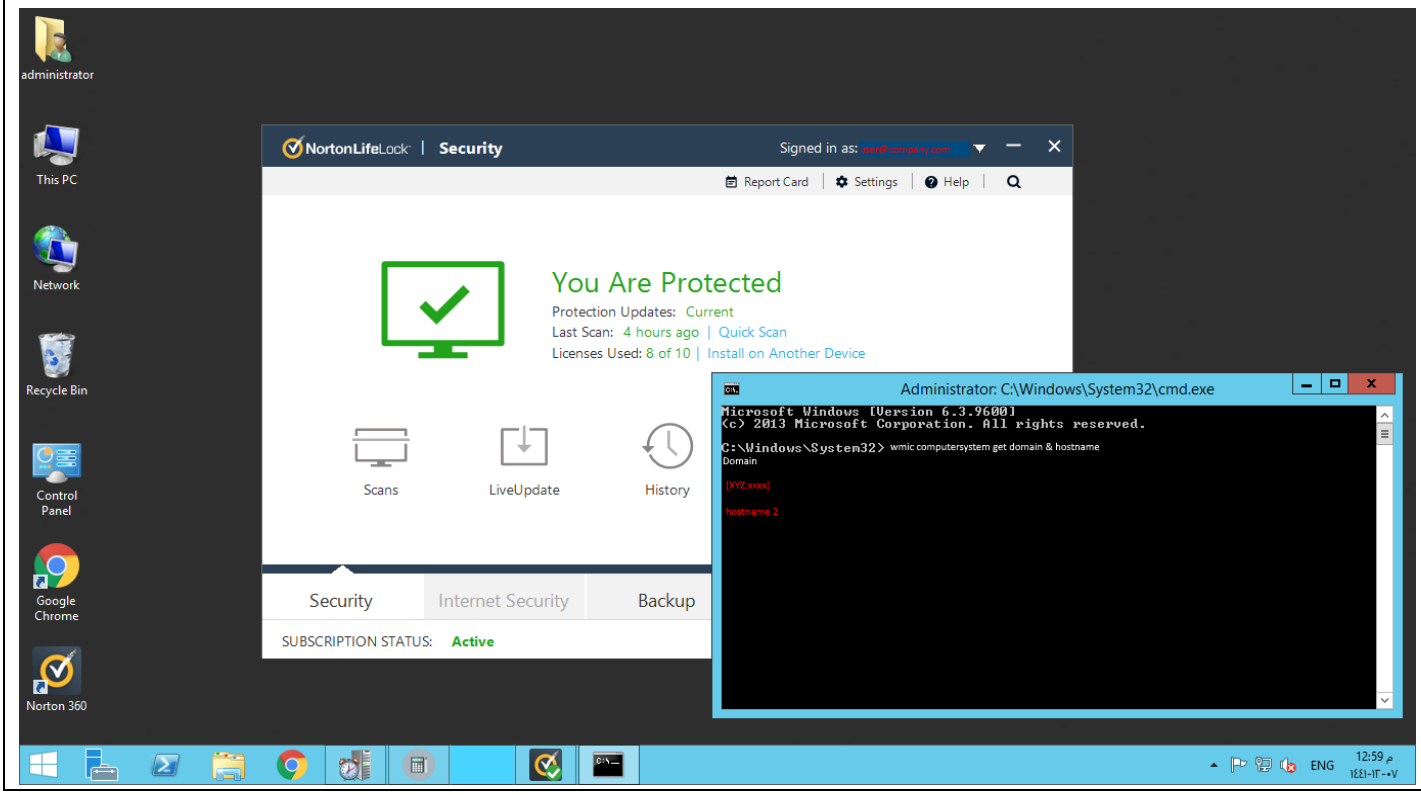


Saudi Aramco: Confidential

Control #	12	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-12	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party Technology Assets must be protected with anti-virus (AV) software. Updates must be applied daily, and full system scans must be performed every two weeks.		

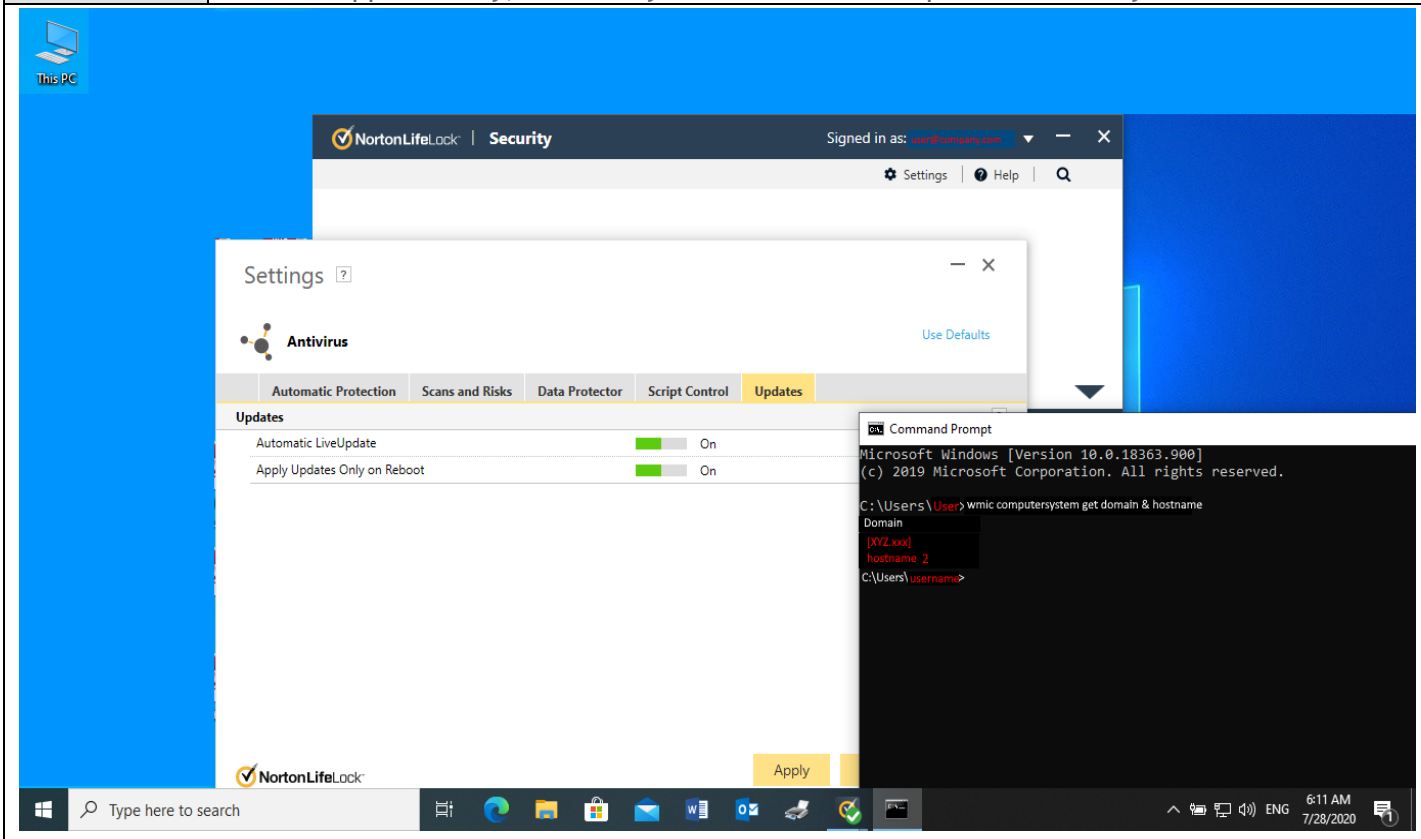


#SS12.4

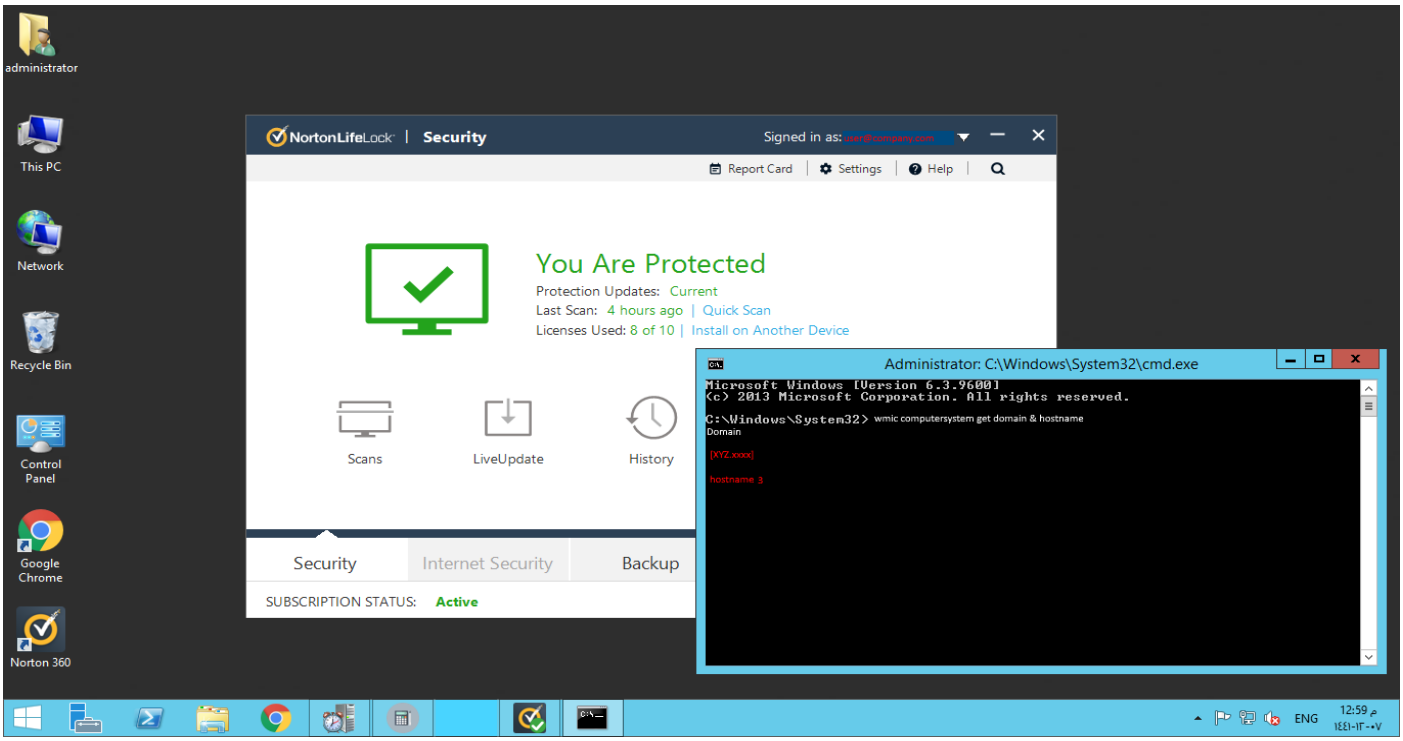


Saudi Aramco: Confidential

Control #	12	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-12	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party Technology Assets must be protected with anti-virus (AV) software. Updates must be applied daily, and full system scans must be performed every two weeks.		

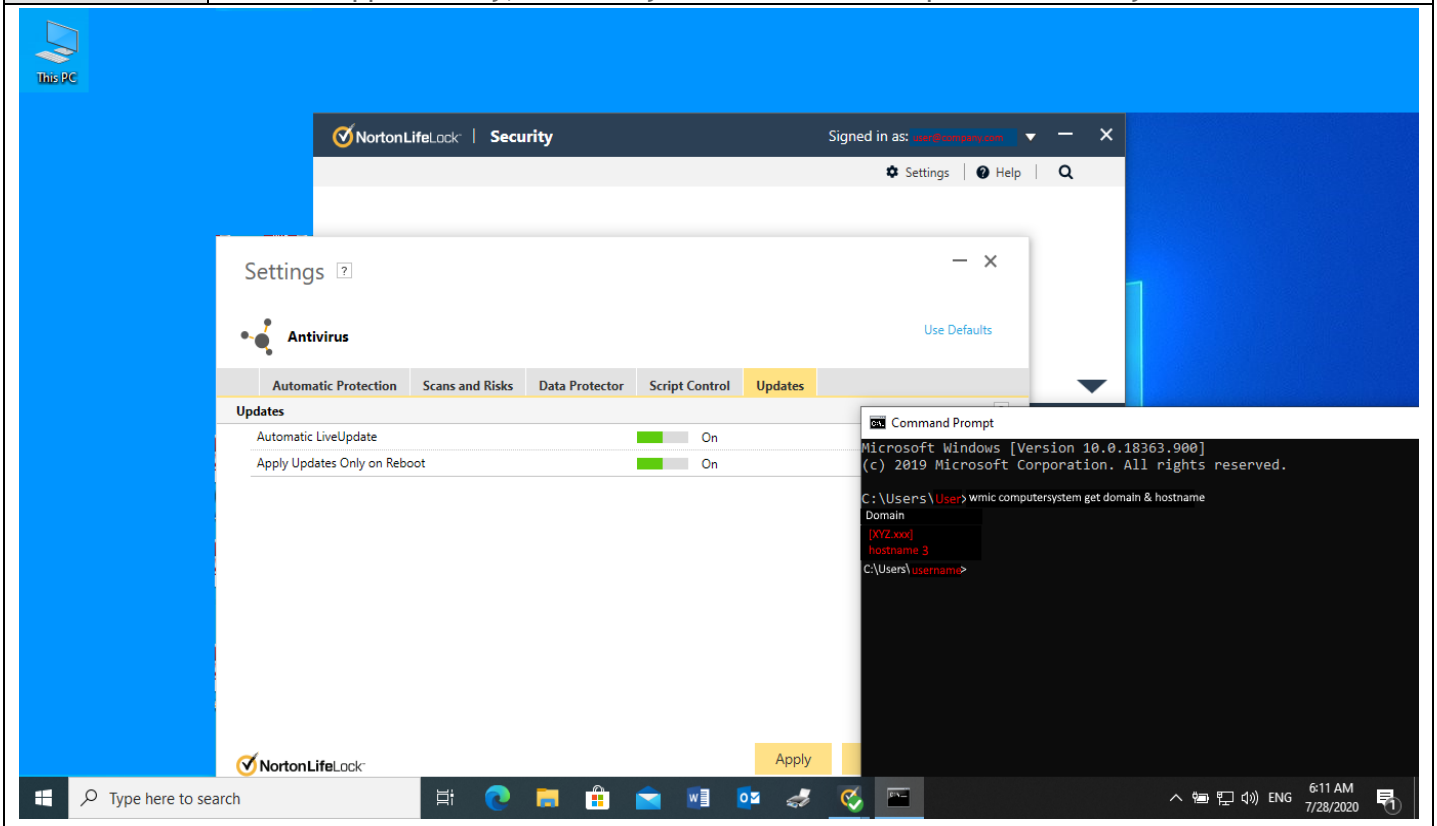


#SS12.5



Saudi Aramco: Confidential

Control #	12	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-12	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party Technology Assets must be protected with anti-virus (AV) software. Updates must be applied daily, and full system scans must be performed every two weeks.		



Compliance Analysis and Remarks

Control Requirement and Compliance analysis:

1) **Provide evidence of the anti-virus installed on endpoint devices.**

Analysis:

2) **Provide evidence of configuration console of the installed anti-virus software to determine thelast updates and full system scan that were performed.**

Analysis:

3) **Provide evidence of the history of updates.**

Analysis:

To be filled by audit firm assessors.

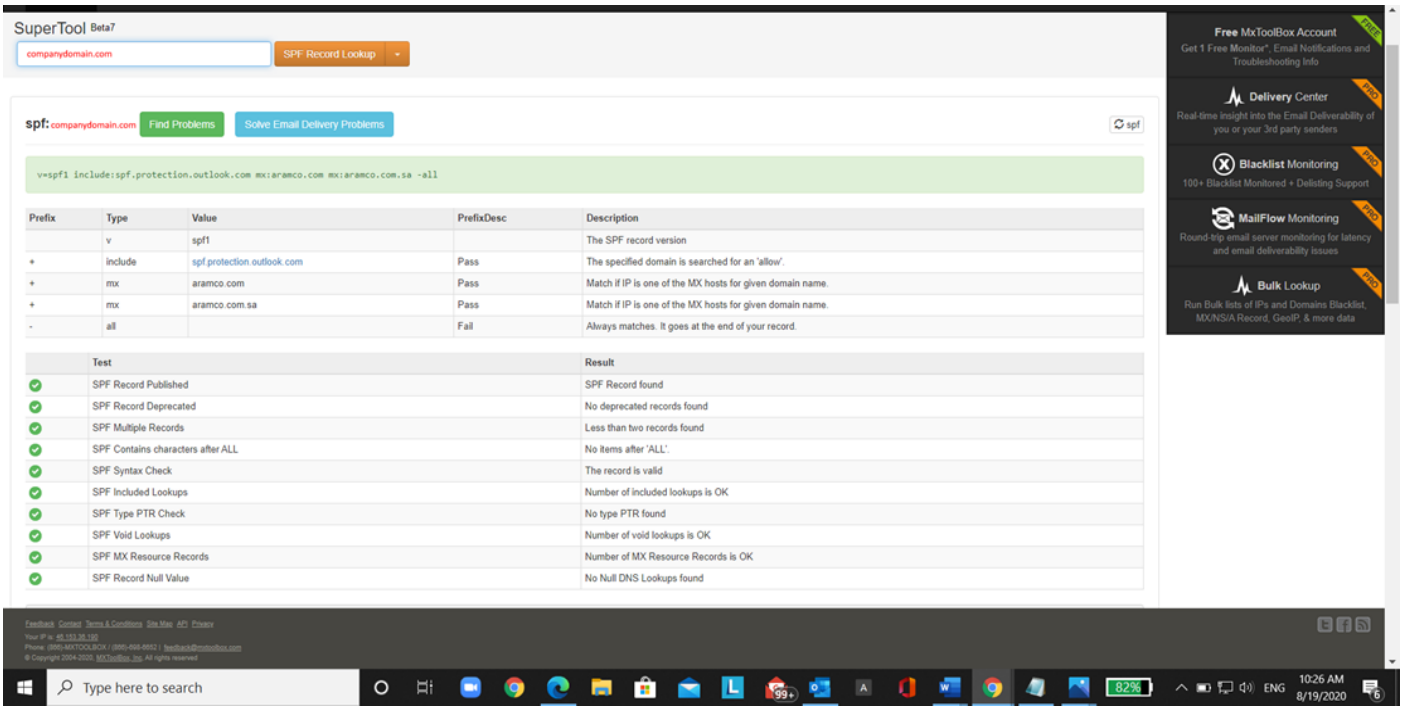
Control #	13	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-13	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must implement Sender Policy Framework (SPF) technology on the mail server.		

Supporting Evidence

Saudi Aramco: Confidential

Control #	13	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-13	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must implement Sender Policy Framework (SPF) technology on the mail server.		

#SS13.1



Compliance Analysis and Remarks

Control Requirements and Compliance Analysis:

1) Provide evidence of SPF implementation on the third party mail server.

Analysis:

To be filled by audit firm assessors.

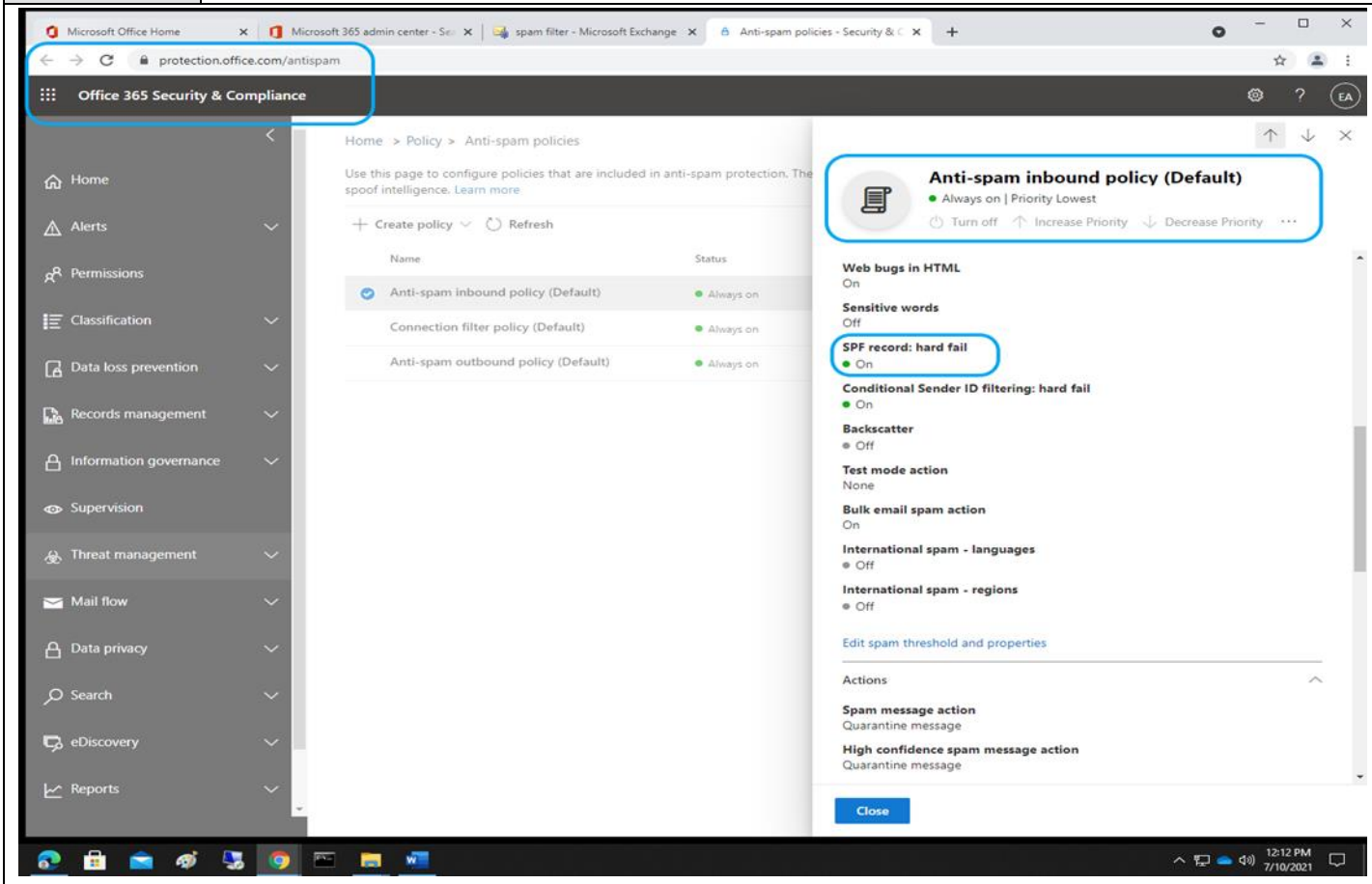
Control #	14	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-14	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must enforce Sender Policy Framework (SPF) feature on Saudi Aramco email domains: Aramco.com and Aramco.com.sa.		

Supporting Evidence

#SS14.1:

Saudi Aramco: Confidential

Control #	14	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-14	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must enforce Sender Policy Framework (SPF) feature on Saudi Aramco email domains: Aramco.com and Aramco.com.sa.		



Compliance Analysis and Remarks

Control Requirements and Compliance Analysis:

1) Provide evidence of SPF enforcement on Saudi Aramco email domains: Aramco.com and Aramco.com.sa.

Analysis:

To be filled by audit firm assessors.

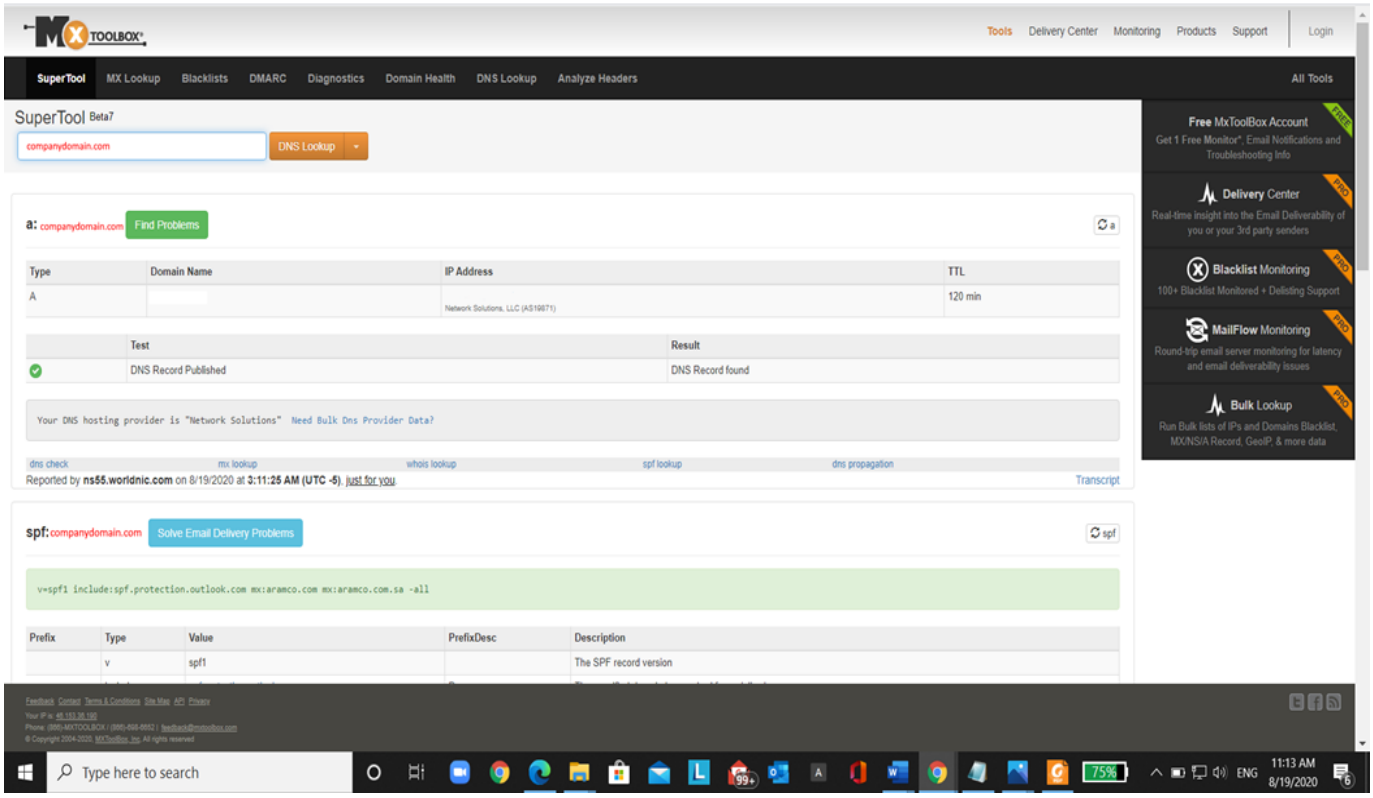
Control #	15	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-15	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must publish SPF record in DNS server.		

Supporting Evidence

#SS15.1

Saudi Aramco: Confidential

Control #	15	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-15	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must publish SPF record in DNS server.		



Compliance Analysis and Remarks

Control Requirement and Compliance Analysis:

1) Provide evidence of SPF record on the third party DNS server.

Analysis:

To be filled by audit firm assessors.

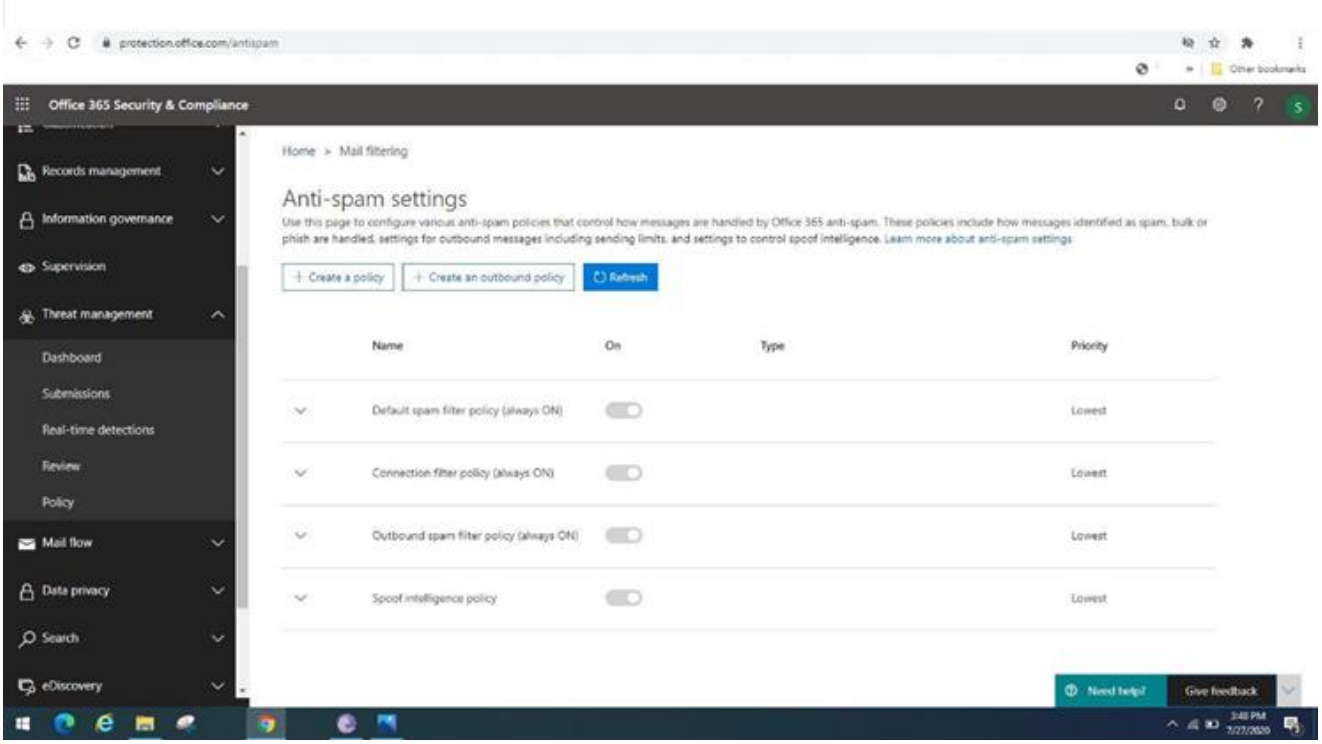
Control #	16	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-16	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inspect all incoming emails originating from the Internet using anti-spam protection.		

Supporting Evidence

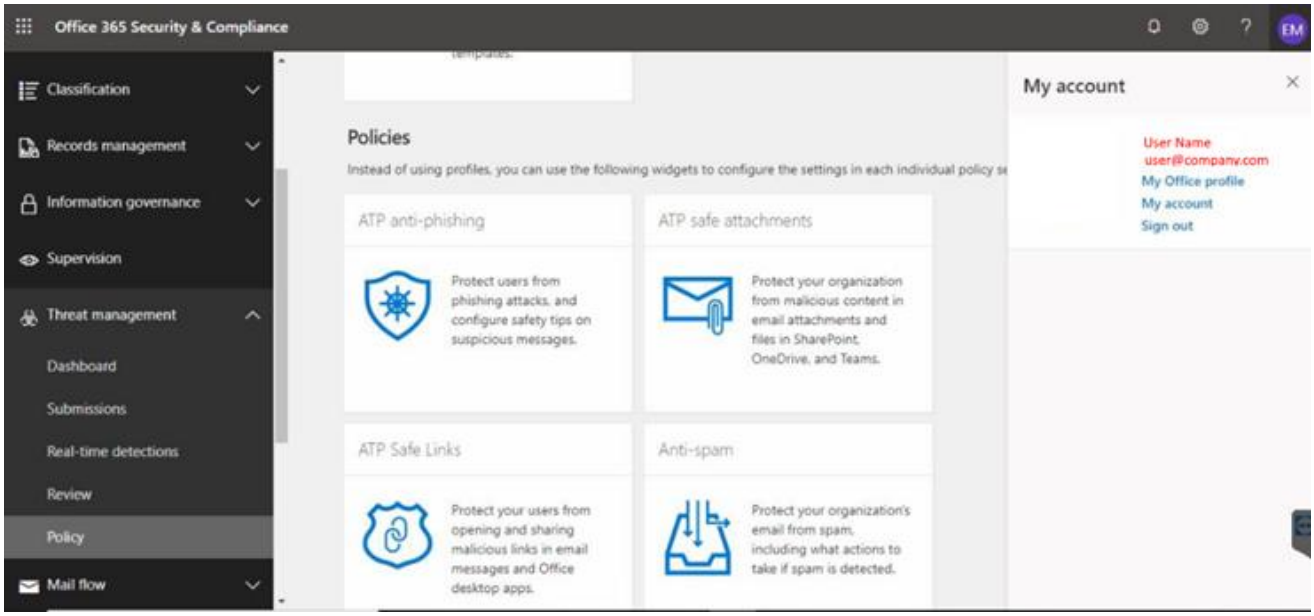
#SS 16.1

Saudi Aramco: Confidential

Control #	16	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-16	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inspect all incoming emails originating from the Internet using anti-spam protection.		



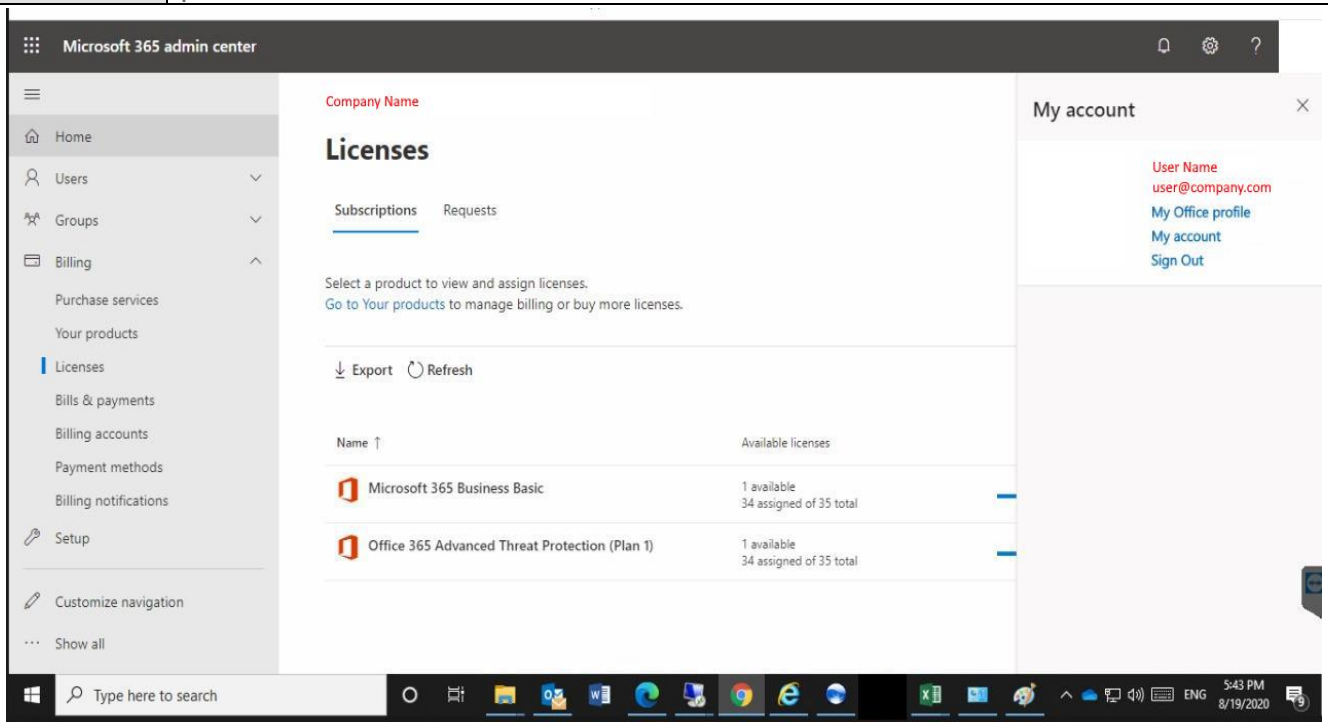
#SS 16.2



#SS 16.3

Saudi Aramco: Confidential

Control #	16	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-16	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must inspect all incoming emails originating from the Internet using anti-spam protection.		



Compliance Analysis and Remarks

Control Requirement and Compliance Analysis

1) Provide evidence of using an anti-spam protection for all incoming emails on the email security appliance.

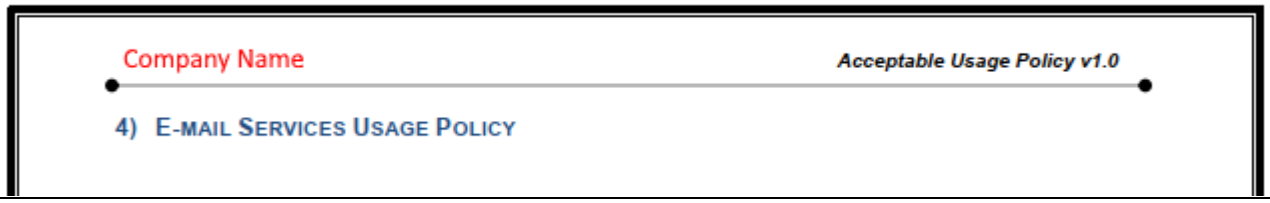
Analysis:

To be filled by audit firm assessors.

Control #	17	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-17	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must use a private email domain. Generic domains, such as Gmail and Hotmail, must not be used.		

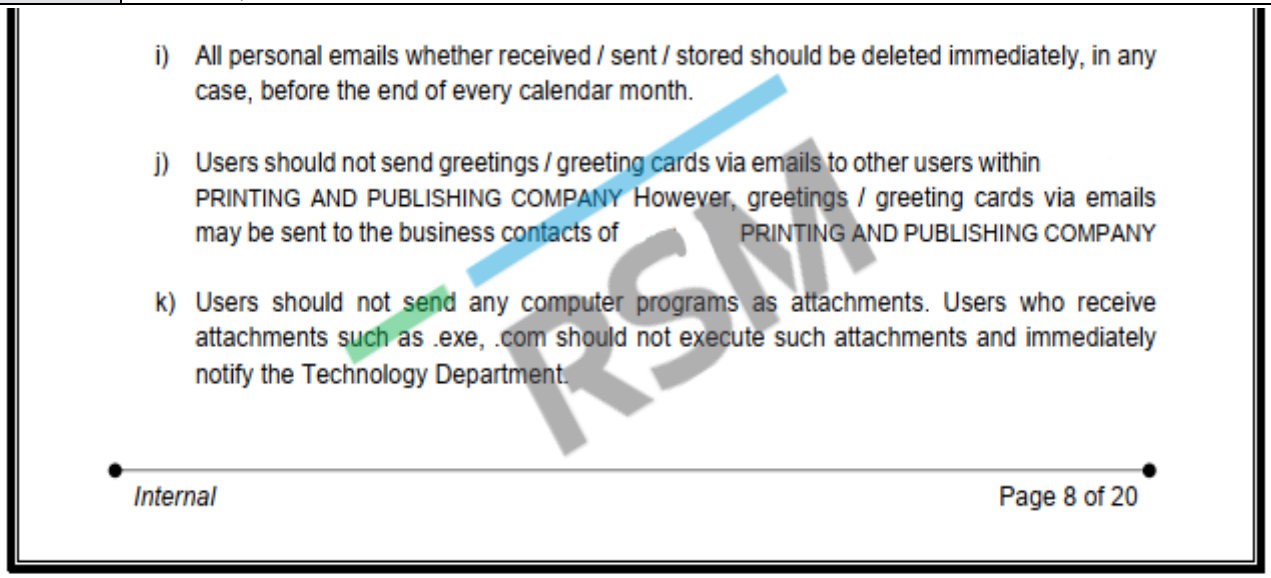
Supporting Evidence

#SS 17.1



Saudi Aramco: Confidential

Control #	17	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-17	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must use a private email domain. Generic domains, such as Gmail and Hotmail, must not be used.		



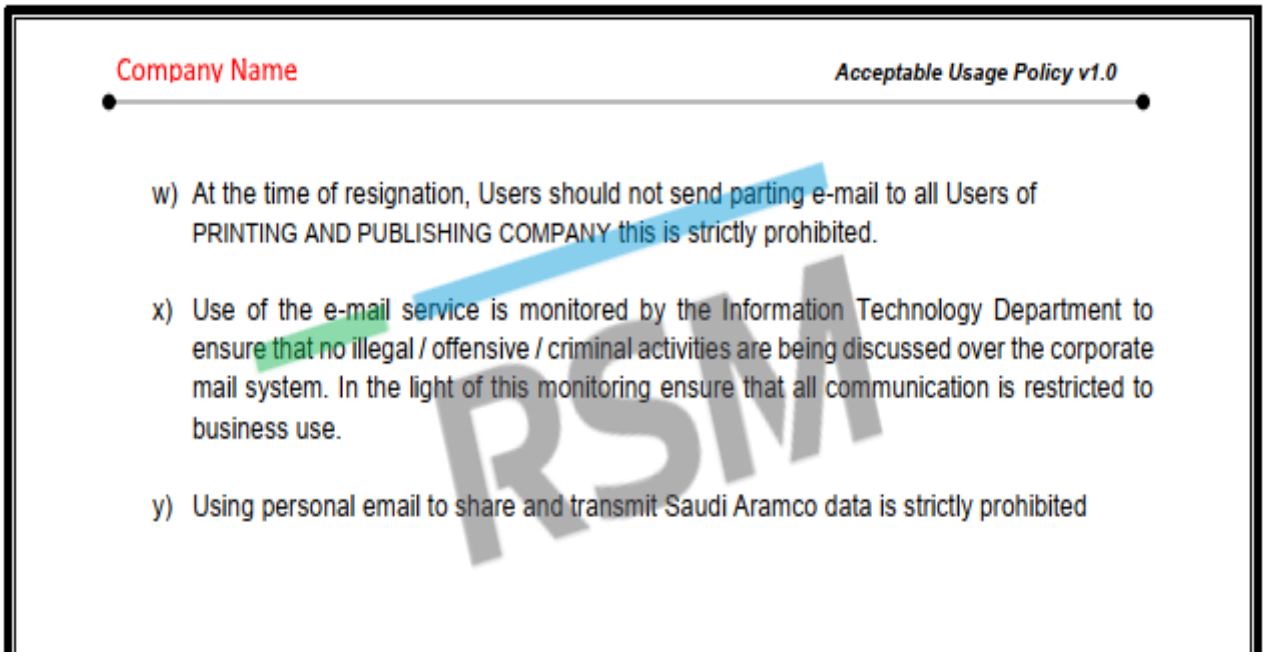
i) All personal emails whether received / sent / stored should be deleted immediately, in any case, before the end of every calendar month.

j) Users should not send greetings / greeting cards via emails to other users within PRINTING AND PUBLISHING COMPANY However, greetings / greeting cards via emails may be sent to the business contacts of PRINTING AND PUBLISHING COMPANY

k) Users should not send any computer programs as attachments. Users who receive attachments such as .exe, .com should not execute such attachments and immediately notify the Technology Department.

Internal Page 8 of 20

#SS 17.3



Company Name *Acceptable Usage Policy v1.0*

w) At the time of resignation, Users should not send parting e-mail to all Users of PRINTING AND PUBLISHING COMPANY this is strictly prohibited.

x) Use of the e-mail service is monitored by the Information Technology Department to ensure that no illegal / offensive / criminal activities are being discussed over the corporate mail system. In the light of this monitoring ensure that all communication is restricted to business use.

y) Using personal email to share and transmit Saudi Aramco data is strictly prohibited

Compliance Analysis and Remarks

Control Requirement and Compliance Analysis:

1) Provide evidence of the third party acceptable use policy (AUP) that highlights the use of the third party private email domain only and prohibit the use of generic domains.

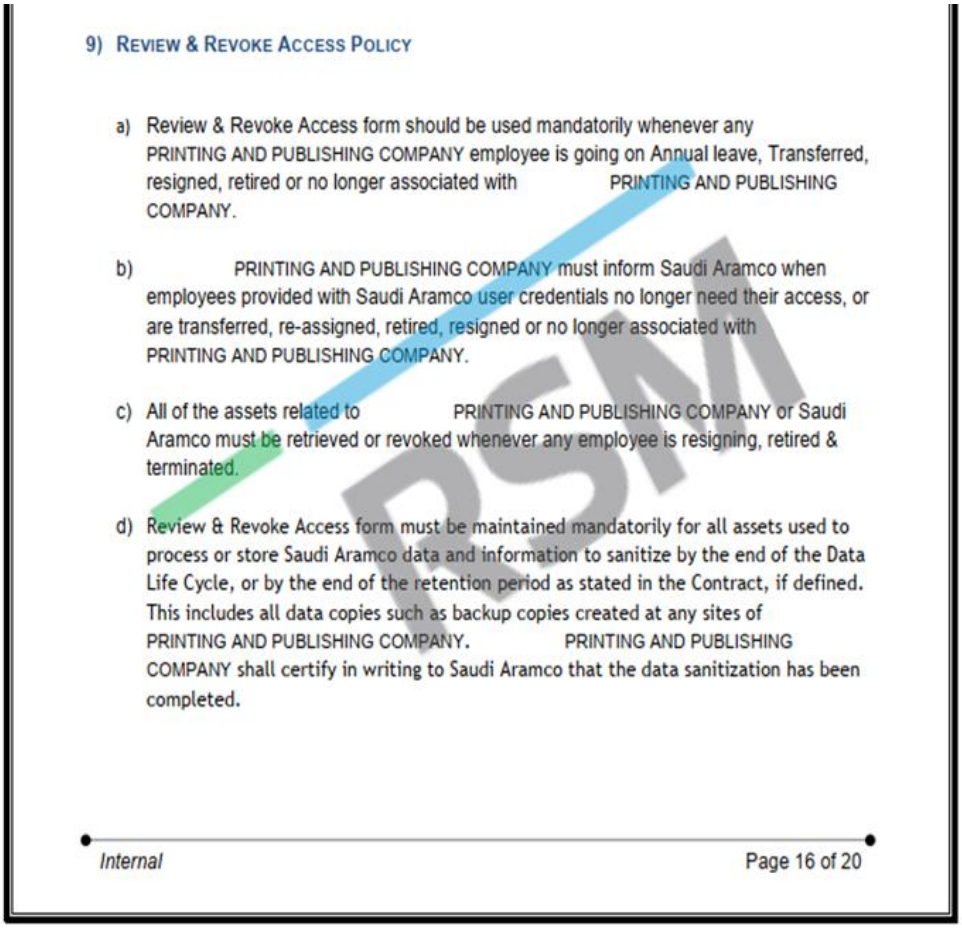
Analysis:

To be filled by audit firm assessors.

Saudi Aramco: Confidential

Control #	18	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-18	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must have formal procedures for off-boarding employees. Off-boarding procedures must include the return of assets, and removal of all associated access.		
Supporting Evidence			

#SS 18.1



9) REVIEW & REVOKE ACCESS POLICY

a) Review & Revoke Access form should be used mandatorily whenever any PRINTING AND PUBLISHING COMPANY employee is going on Annual leave, Transferred, resigned, retired or no longer associated with PRINTING AND PUBLISHING COMPANY.

b) PRINTING AND PUBLISHING COMPANY must inform Saudi Aramco when employees provided with Saudi Aramco user credentials no longer need their access, or are transferred, re-assigned, retired, resigned or no longer associated with PRINTING AND PUBLISHING COMPANY.

c) All of the assets related to PRINTING AND PUBLISHING COMPANY or Saudi Aramco must be retrieved or revoked whenever any employee is resigning, retired & terminated.

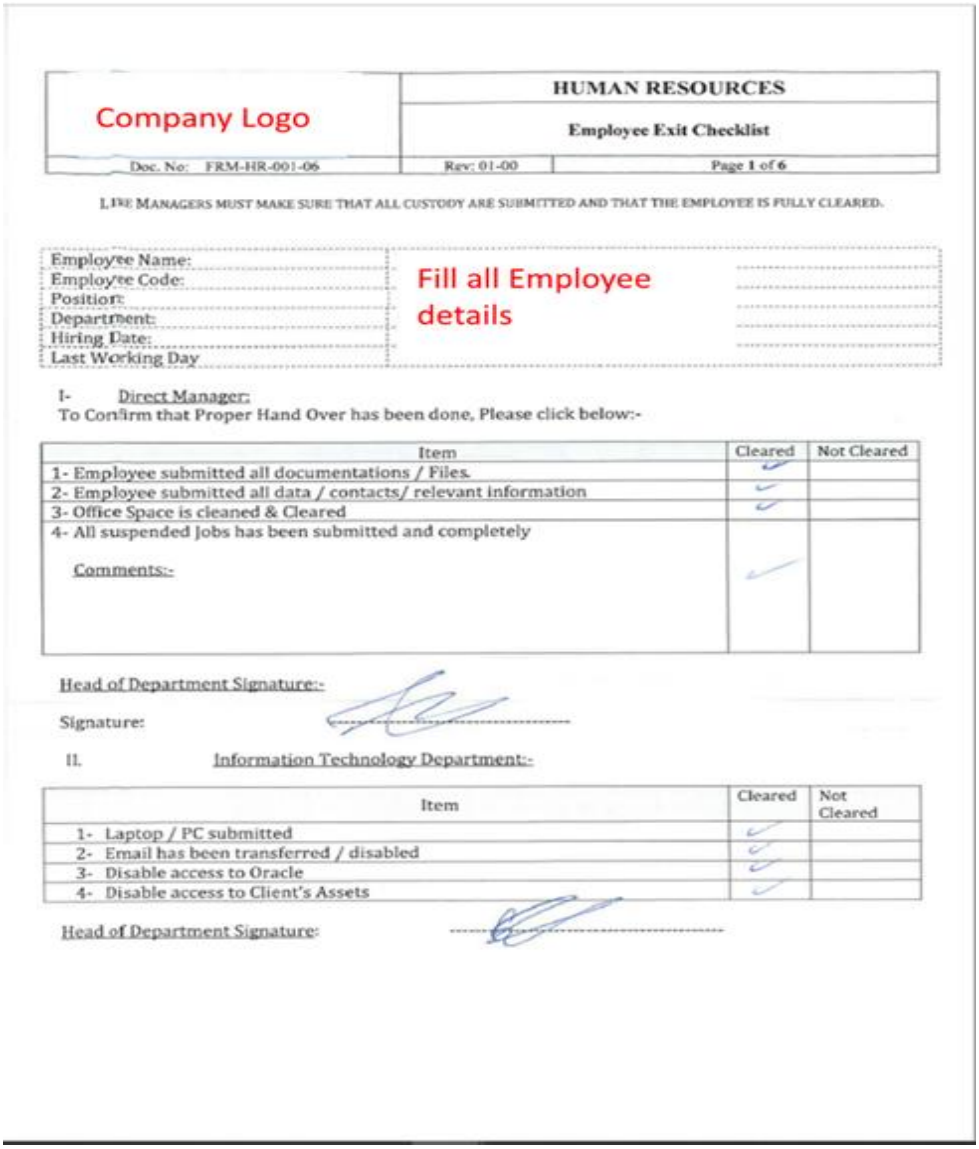
d) Review & Revoke Access form must be maintained mandatorily for all assets used to process or store Saudi Aramco data and information to sanitize by the end of the Data Life Cycle, or by the end of the retention period as stated in the Contract, if defined. This includes all data copies such as backup copies created at any sites of PRINTING AND PUBLISHING COMPANY. PRINTING AND PUBLISHING COMPANY shall certify in writing to Saudi Aramco that the data sanitization has been completed.

Internal Page 16 of 20

#SS 18.2

Saudi Aramco: Confidential

Control #	18	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-18	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must have formal procedures for off-boarding employees. Off-boarding procedures must include the return of assets, and removal of all associated access.		



Company Logo

HUMAN RESOURCES

Employee Exit Checklist

Doc. No: FRM-HR-001-06 | Rev: 01-00 | Page 1 of 6

LINE MANAGERS MUST MAKE SURE THAT ALL CUSTODY ARE SUBMITTED AND THAT THE EMPLOYEE IS FULLY CLEARED.

Employee Name:
Employee Code:
Position:
Department:
Hiring Date:
Last Working Day

Fill all Employee details

I- Direct Manager:
To Confirm that Proper Hand Over has been done, Please click below:-

Item	Cleared	Not Cleared
1- Employee submitted all documentations / Files.	✓	
2- Employee submitted all data / contacts/ relevant information	✓	
3- Office Space is cleaned & Cleared	✓	
4- All suspended Jobs has been submitted and completely		
Comments:-	✓	

Head of Department Signature:-

Signature: .....

II. Information Technology Department:-

Item	Cleared	Not Cleared
1- Laptop / PC submitted	✓	
2- Email has been transferred / disabled	✓	
3- Disable access to Oracle	✓	
4- Disable access to Client's Assets	✓	

Head of Department Signature: .....

Compliance Analysis and Remarks

Control Requirement and Compliance Analysis:

1) Provide evidence of the third party termination procedures to determine whether accounts/access are disabled in a timely manner.

Analysis:

2) Provide samples of the removal of all access to Assets part of the third party Off-boarding procedures.

Analysis:

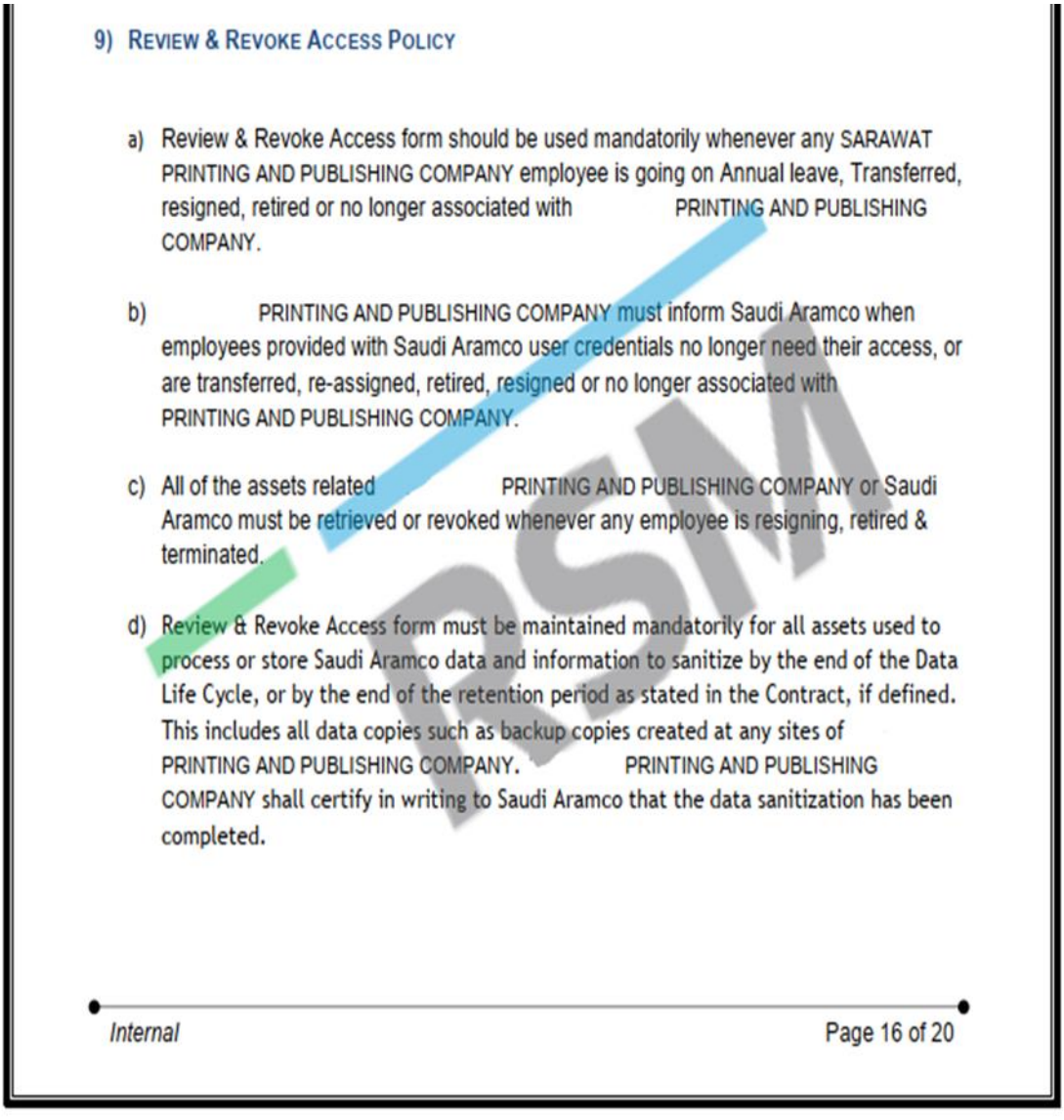
To be filled by audit firm assessors.

Saudi Aramco: Confidential

Control #	19	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-19	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Assets used to process or store Saudi Aramco data and information must be sanitized by the end of the Data Life Cycle, or by the end of the retention period as stated in the Contract, if defined. This includes all data copies such as backup copies created at any Third Party site(s). Third Party shall certify in writing to Saudi Aramco that the data sanitization has been completed.		

Supporting Evidence

#SS 19.1



9) REVIEW & REVOKE ACCESS POLICY

a) Review & Revoke Access form should be used mandatorily whenever any SARAWAT PRINTING AND PUBLISHING COMPANY employee is going on Annual leave, Transferred, resigned, retired or no longer associated with PRINTING AND PUBLISHING COMPANY.

b) PRINTING AND PUBLISHING COMPANY must inform Saudi Aramco when employees provided with Saudi Aramco user credentials no longer need their access, or are transferred, re-assigned, retired, resigned or no longer associated with PRINTING AND PUBLISHING COMPANY.

c) All of the assets related PRINTING AND PUBLISHING COMPANY or Saudi Aramco must be retrieved or revoked whenever any employee is resigning, retired & terminated.

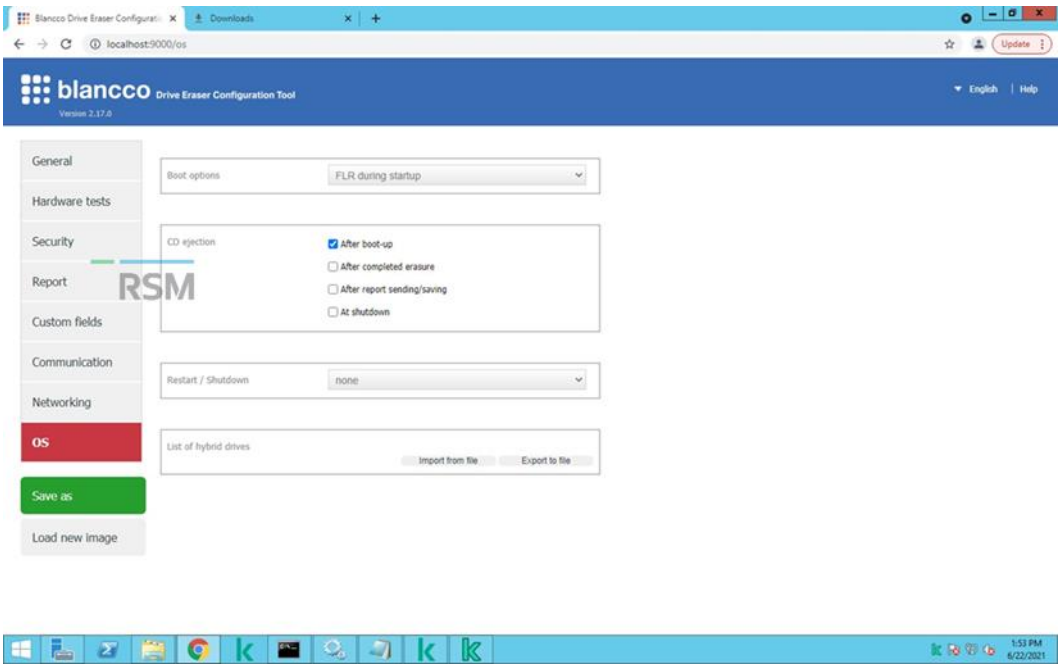
d) Review & Revoke Access form must be maintained mandatorily for all assets used to process or store Saudi Aramco data and information to sanitize by the end of the Data Life Cycle, or by the end of the retention period as stated in the Contract, if defined. This includes all data copies such as backup copies created at any sites of PRINTING AND PUBLISHING COMPANY. PRINTING AND PUBLISHING COMPANY shall certify in writing to Saudi Aramco that the data sanitization has been completed.

Internal Page 16 of 20

#SS 19.2

Saudi Aramco: Confidential

Control #	19	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-19	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Assets used to process or store Saudi Aramco data and information must be sanitized by the end of the Data Life Cycle, or by the end of the retention period as stated in the Contract, if defined. This includes all data copies such as backup copies created at any Third Party site(s). Third Party shall certify in writing to Saudi Aramco that the data sanitization has been completed.		



Compliance Analysis and Remarks

Control Requirement and Compliance Analysis:

1) Provide evidence of the third party sanitization (data destruction) policies.

Analysis:

2) Provide evidence of sanitization techniques and procedures are commensurate with the security category or classification of the information or asset and in accordance with organizational standards and policies.

Analysis:

To be filled by audit firm assessors.

Control #	20	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-20	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must obtain a Cybersecurity Compliance Certificate (CCC) from Saudi Aramco authorized audit firms in accordance to the third-Party classification requirements set forth in this Standard (Section II). Third Parties must submit the CCC to Saudi Aramco through the Saudi Aramco e-Marketplace system.		

Supporting Evidence

Compliance Analysis and Remarks

Control Requirements and Compliance Analysis:

Saudi Aramco: Confidential

Control #	20	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-20	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must obtain a Cybersecurity Compliance Certificate (CCC) from Saudi Aramco authorized audit firms in accordance to the third-Party classification requirements set forth in this Standard (Section II). Third Parties must submit the CCC to Saudi Aramco through the Saudi Aramco e-Marketplace system.		

1) Saudi Aramco third parties must obtain a Cybersecurity Compliance Certificate (CCC) from Saudi Aramco authorized audit firms, which provides the adherence to this standard.

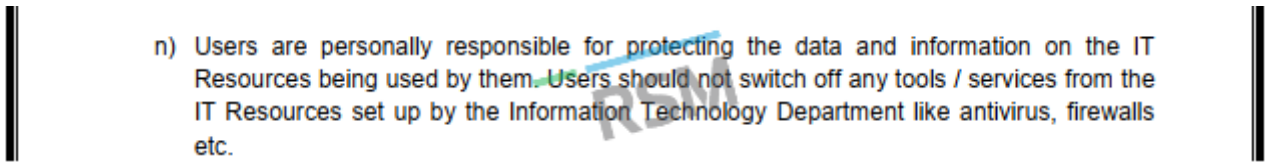
Analysis:

To be filled by audit firm assessors.

Control #	21	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-21	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Third Party must renew the CCC every two (2) years.		
Supporting Evidence			
Compliance Analysis and Remarks			
Remarks We have noted that since this is the first time …. **To be filled by audit firm assessors.**			

Control #	22	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-22	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Firewalls must be configured and enabled on endpoint devices.		
Supporting Evidence			

#SS22.1



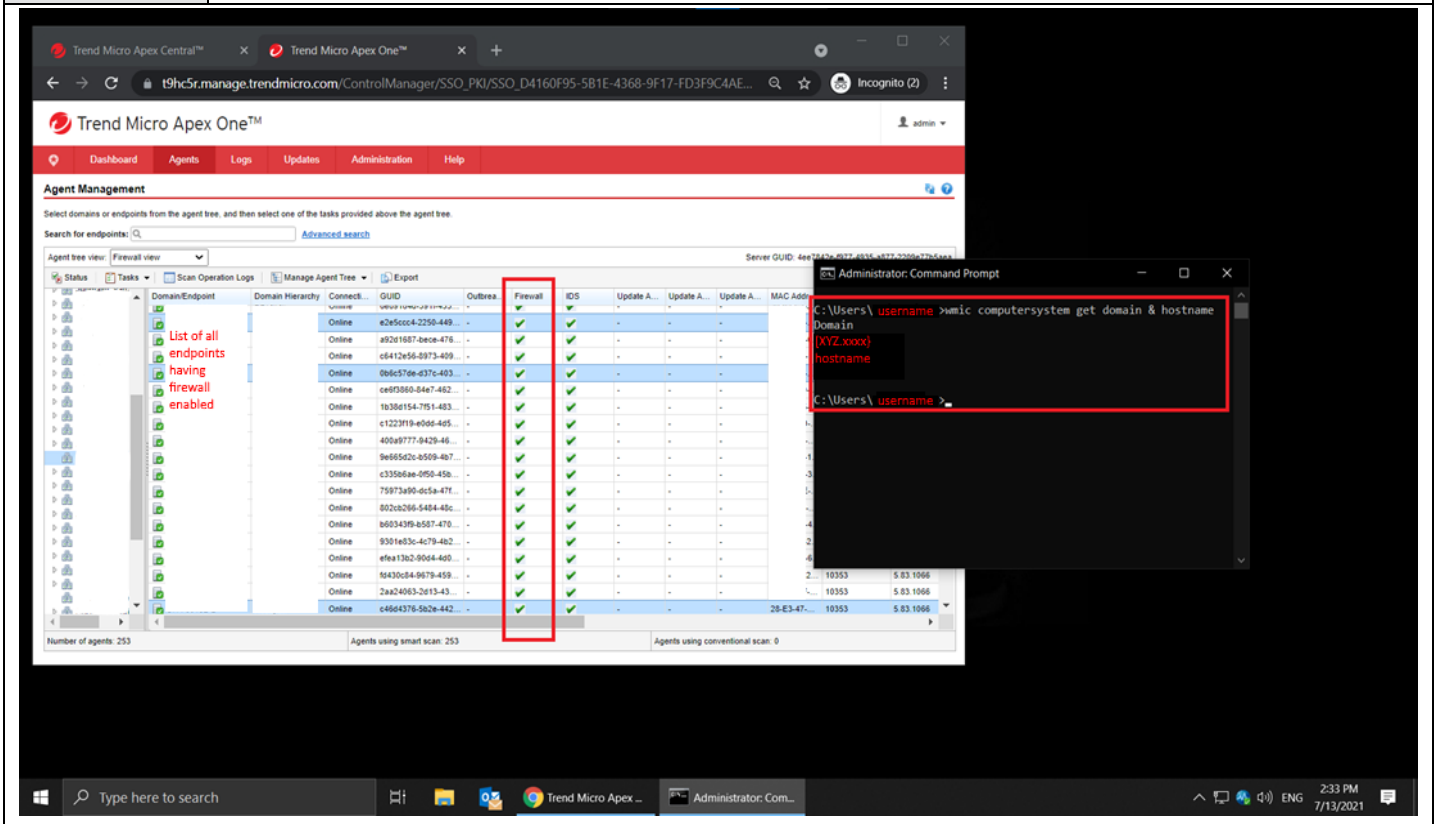
n) Users are personally responsible for protecting the data and information on the IT Resources being used by them. Users should not switch off any tools / services from the IT Resources set up by the Information Technology Department like antivirus, firewalls etc.

#SS22.2

Firewall policy enabled from the console:

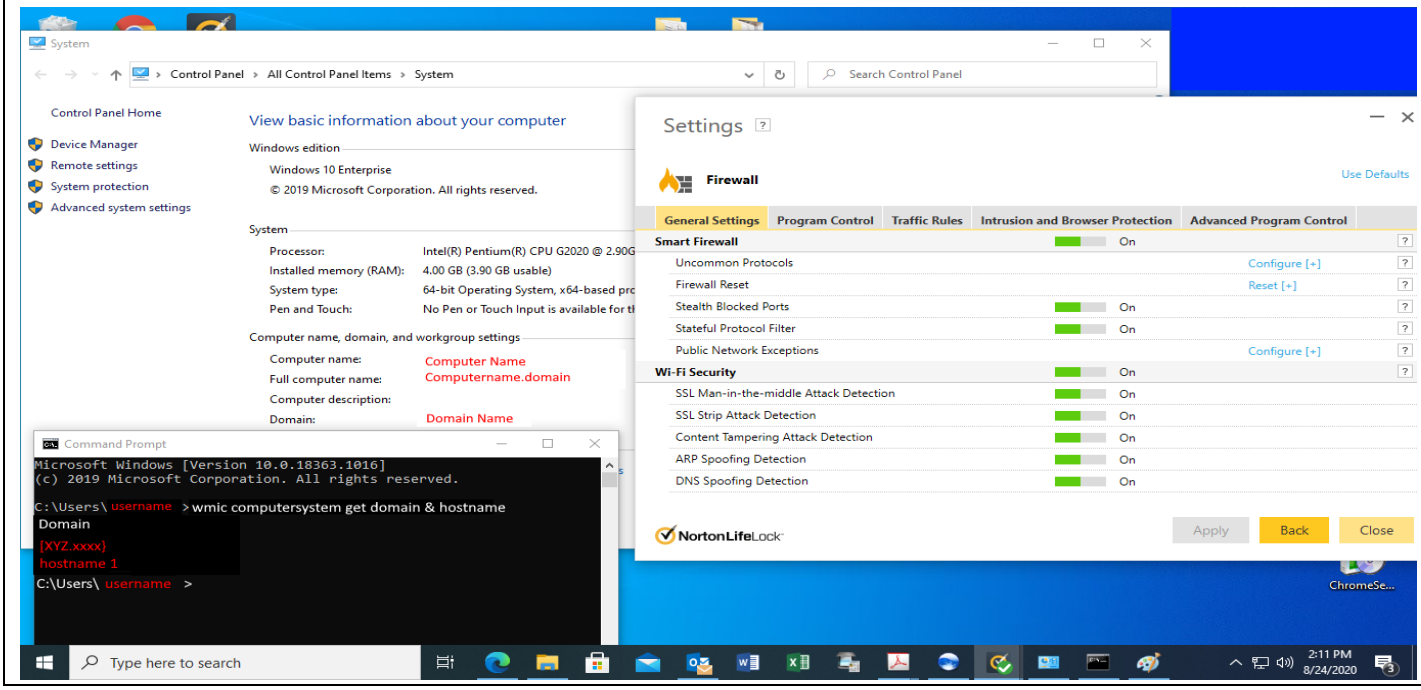
Saudi Aramco: Confidential

Control #	22	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-22	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Firewalls must be configured and enabled on endpoint devices.		



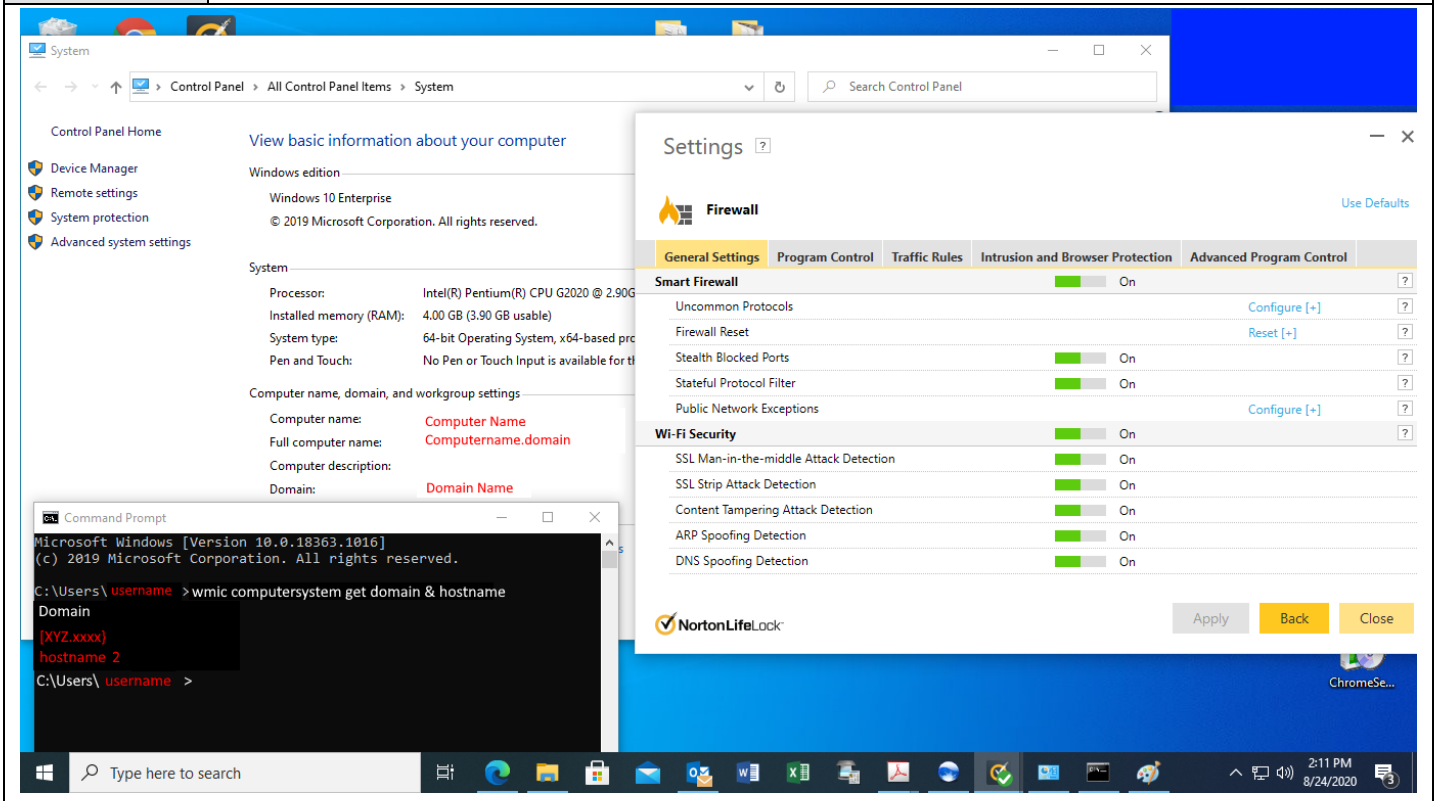
Host firewall from the AV Solution - At least from 3 users:

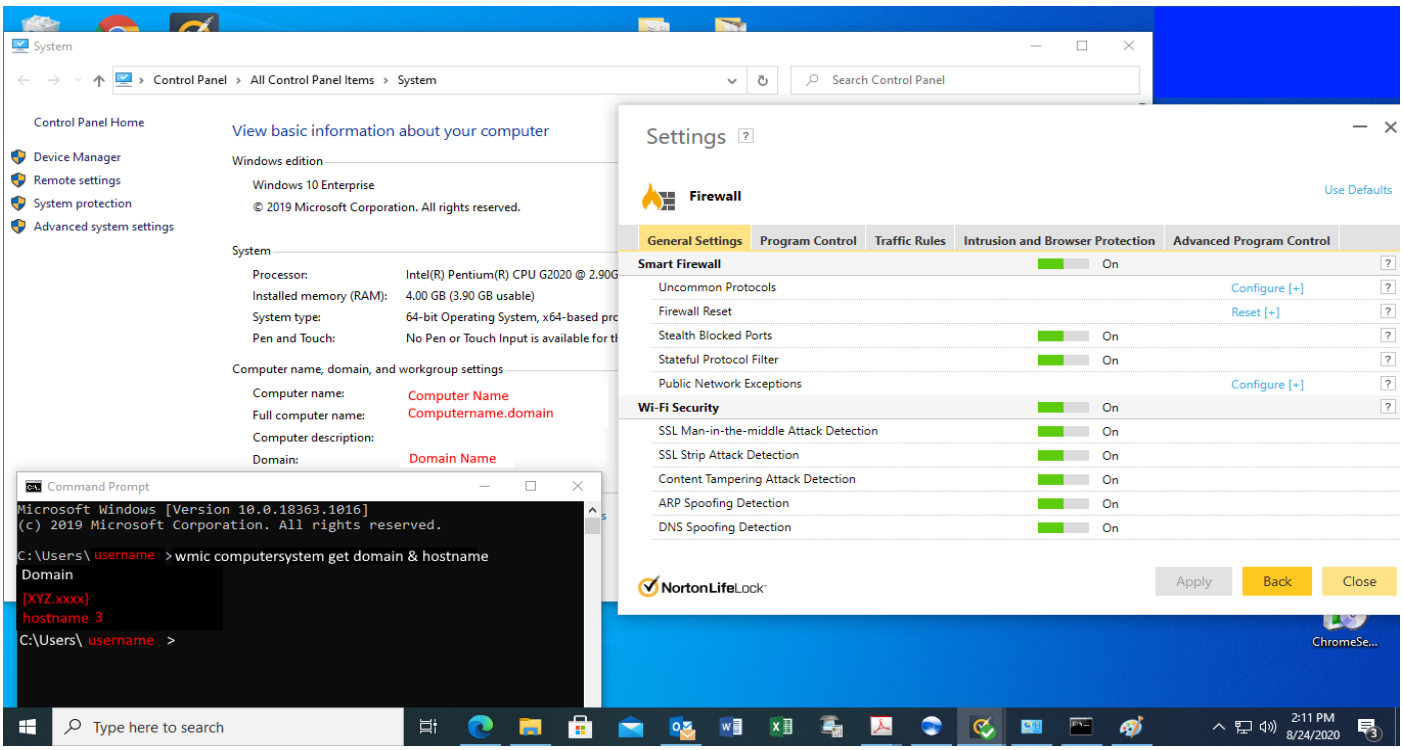
#SS22.3



Saudi Aramco: Confidential

Control #	22	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-22	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Firewalls must be configured and enabled on endpoint devices.		



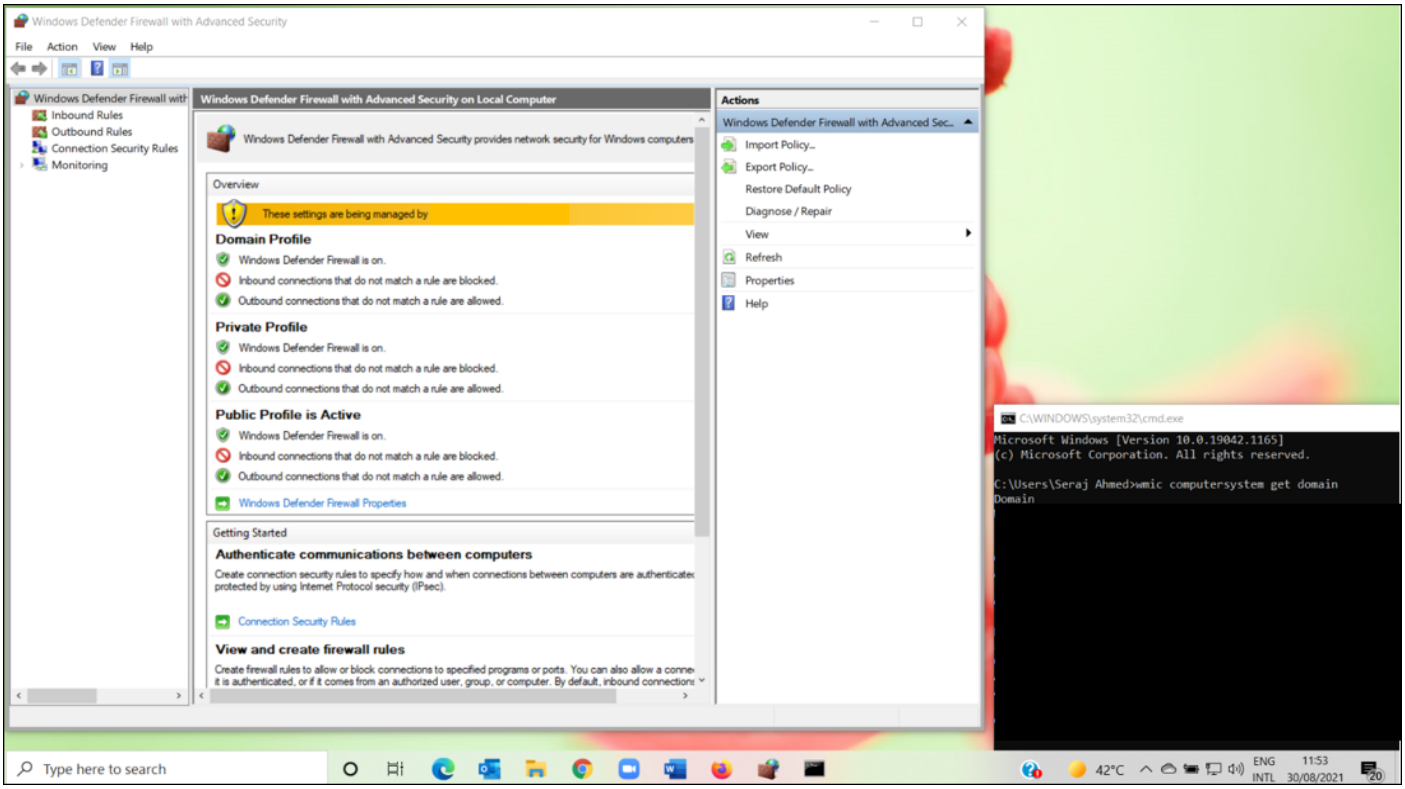


Saudi Aramco: Confidential

Control #	22	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-22	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	Firewalls must be configured and enabled on endpoint devices.		

Windows firewall – At least from 3 users:

#SS22.4



Compliance Analysis and Remarks

Control Requirements and Compliance Analysis:

1) Provide evidence of the firewall setting for all third party endpoint devices including related policies for enabling firewalls.

Analysis:

2) Provide evidence of the firewall being enabled on domain, public and private firewall settings on sample of third party endpoint devices.

Analysis:

To be filled by audit firm assessors.

Control #	23	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-23	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	If Third Party discovers a Cybersecurity Incident, Third Party must (besides its continuous efforts to resolve and mitigate the Incident): - Notify SAUDI ARAMCO within twenty-four (24) hours of discovering the Incident - Follow the Cybersecurity Incident Response Instructions set forth in Appendix A		

Supporting Evidence

Saudi Aramco: Confidential

Control #	23	Compliance Status	☐ Compliance ☐ Non-Compliance ☐ Not Applicable [To be filled by audit firm assessors]
Reference #	TPC-23	Source	SACS-002 Third Party Cybersecurity Standard
Control Statement	If Third Party discovers a Cybersecurity Incident, Third Party must (besides its continuous efforts to resolve and mitigate the Incident): - Notify SAUDI ARAMCO within twenty-four (24) hours of discovering the Incident - Follow the Cybersecurity Incident Response Instructions set forth in Appendix A		

#SS 23.1

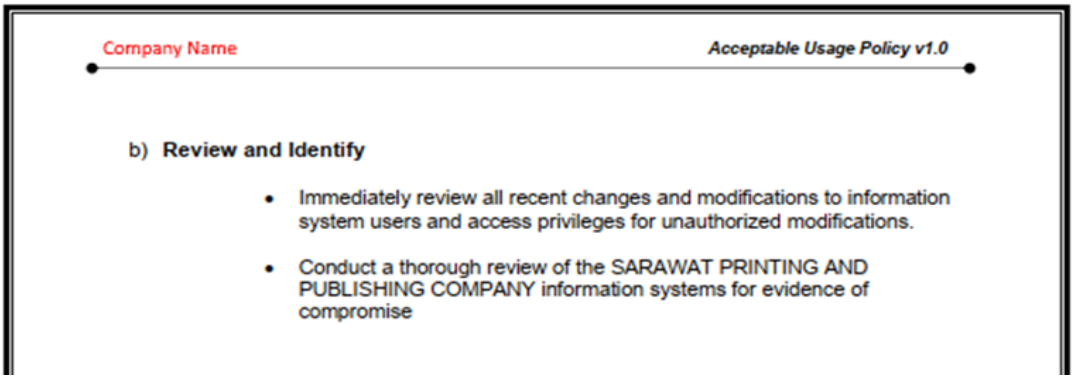


11) INCIDENT MANAGEMENT POLICY RELATED TO SAUDI ARAMCO

a) **Notify**

- Notify Saudi Aramco of the Incident
- *Initial Notification of Incident:* PRINTING AND PUBLISHING COMPANY should notify Saudi Aramco Security Operations Center (SOC) within two (2) hours of discovering any Incident.
- All notifications should be communicated to SOC via the Saudi Aramco Security Hotline at: +966 (13)-880-0000.
- Subsequent Notification of Incident: After the Initial Notification of the Incident, PRINTING AND PUBLISHING COMPANY must notify Saudi Aramco of all Incidents stemming from the initial Incident via the communication method agreed by SOC during the initial notification.

Internal Page 17 of 20



Company Name *Acceptable Usage Policy v1.0*

b) **Review and Identify**

- Immediately review all recent changes and modifications to information system users and access privileges for unauthorized modifications.
- Conduct a thorough review of the SARAWAT PRINTING AND PUBLISHING COMPANY information systems for evidence of compromise

Compliance Analysis and Remarks

Control Requirement and Compliance Analysis:

1) Provide evidence of the third party cybersecurity Incident management policies and procedures that conform with the requirements of this control.

Analysis:

To be filled by audit firm assessors.

Saudi Aramco: Confidential

7. Report Summary

	Compliance	Not Applicable	Non-Compliance
Count	x	z	y
Percentage	%	%	%
Percentage of Compliance and Not Applicable	%		

Appendix A - Third Party Classification

SACS-002 Third Party Cybersecurity Standard required cybersecurity controls that are considered to be among the best practices in Cybersecurity such as the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) in which this standard is aligned to. All Third Parties must comply with all cybersecurity controls specified in General Requirements. In addition, specific cybersecurity requirements are defined for a Third Party whom below classes might describe:

- **Network Connectivity:** Third Party is provided with network connectivity to Saudi Aramco Corporate Network to access Saudi Aramco intranet services and preform required work. This connectivity is provided through leased lines or through certain VPN solutions such as SSL VPN over private links or site-to-site VPN over the Internet.
- **Outsourced Infrastructure:** Third Party is outsourced to manage, maintain and/or support an infrastructure on behalf of Saudi Aramco.
- **Critical Data Processor:** Third Party is developing, accessing and/or processing Saudi Aramco Critical Data.
- **Customized Software:** Third Party is outsourced to develop and/or host a customized software, application, website or solution for Saudi Aramco.

Saudi Aramco: Confidential